ANEXO I

TERMO DE REFERÊNCIA

1. OBJETO

A presente licitação objetiva a contratação de empresa especializada na prestação de Serviços de Segurança da Informação por meio de Plataforma integrada de solução de gestão de segurança de dados, em atendimento a Lei Geral de Proteção de Dados (LGPD), conforme condições estabelecidas neste Termo de Referência e seus anexos, incluindo suporte técnico, garantia e manutenção de versões, operação assistida, serviços de instalação e configuração da solução, treinamento, integrações necessárias com soluções de terceiros para atender às demandas da Unidade Municipal De Tecnologia e Informação/ UMTI, pelo período de 12 (doze) meses.

2. JUSTIFICATIVA

2.1 Origem e necessidade da demanda

2.2 A origem e justificativa da presente demanda recai sobre o tema Segurança da Informação e seus impactos no ambiente computacional dessa municipalidade, permitirá a implementação de uma solução/estratégia tecnológica relacionada a segurança dos dados custodiados e informações transacionadas pelo ambiente computacional do Município de João Pessoa e suas aplicações, promovendo ainda a adequação do município às determinações da Lei Geral de Proteção de Dados (LGPD), Lei Federal nº 13.709/2018.

2.3 De forma clara e objetiva, a presente demanda busca a identificação de uma solução e/ou estratégia tecnológica capaz de proporcionar maior visibilidade dos eventos de segurança da informação, permitindo às equipes do município agir de forma proativa evitando eventuais vazamentos de dados. À medida que os ciberataques são detectados em sua fase inicial, permitirá ainda a identificação de soluções de proteção contra ameaças avançadas, por meio de tecnologias capazes de analisar e detectar tráfego malicioso em tempo real em diversos vetores diferentes.

2.4 Já em relação a citada adequação regulatória, conforme determinou o art. 6º, incisos VII e VIII, da LGPD, o tratamento de dados deve observar a segurança e a prevenção, ambos englobando a "utilização de medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão" e a "adoção de medidas para prevenir a ocorrência de danos em virtude do tratamento de dados pessoais".

2.5 No que se refere a justificativa para tal adequação, há que se considerar a onda de ciberataques nos últimos anos a grandes empresas do setor privado e a setores ligados a infraestrutura do poder público, posicionando os temas segurança digital e segurança da informação entre as prioridades das agendas governamentais.

2.6 Nesse contexto, diversos tipos de crimes digitais, estão relacionados ao vazamento de dados ou ainda à ataques do tipo “Ransomware”. Trata-se aqui de uma categoria de malware composta por aplicações maliciosas que acessam sistemas clandestinamente, “sequestram” dados do computador ou servidor infectado. Após esse acesso aos dados, o agente malicioso criptografa todas as informações do usuário, em seguida, cyber-criminosos cobram pelo resgate dos dados, normalmente via bitcoins ou outras operações não rastreáveis.

2.7 Diante do significativo aumento no volume de ataques a ambientes de tecnologia, é de conhecimento amplo, seja pelo mercado privado ou governamental, que inúmeras soluções baseadas em software e/ou plataformas foram desenvolvidas com o objetivo de mitigar os riscos associados aos citados eventos, a exemplo de soluções de firewall, soluções de prevenção de vazamento de dados, soluções específicas de criptografia, solução denominadas como “WAF”, que representam um firewall de aplicativos Web capaz de filtrar, monitorar e bloquear o conteúdo de aplicativos web específicos, dentre outros recursos e ferramentas que serão estudadas e evidenciadas por meio do presente termo de referência.

2.8 No contexto particular desse município, nos últimos anos o município de João Pessoa desenvolveu um conjunto amplo de iniciativas e práticas com o objetivo de priorizar e potencializar a excelência nos serviços prestados ao cidadão, bem como às instituições públicas e privadas que se interrelacionam com essa municipalidade, a exemplo dos recentes investimentos na reestruturação do parque tecnológico de suas secretarias, uma iniciativa que possibilita uma melhor prestação de serviço ao cidadão e mais segurança aos dados públicos.

2.9 Espera-se que a solução a ser contratada seja capaz de garantir maior efetividade dos controles de eventos de segurança, prevenção de vazamento de dados, desenvolver estratégias que possam inibir a tentativa de busca e vazamento de informações que possam comprometer a segurança de dados dos órgãos, secretarias e autarquias no âmbito da administração pública que tenham relação direta com este município, bem como reduzir riscos de ataques ao ambiente computacional.

2.10 Importante ressaltar que as informações tratadas por essa Instituição são ativos valiosos para a eficiente prestação dos serviços públicos, é por este motivo que se busca, através da presente demanda, desenvolver ações que objetivam viabilizar e assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade das informações, assegurando a qualidade dos serviços públicos esperados pela população, garantindo a segurança com relação à guarda de "dados sensíveis" pelo governo, através da adoção de medidas rigorosas de segurança para acesso dessas informações.

2.11 Destaca-se, por fim, que o presente Termo de Referência busca uma solução que permitirá à essa administração estar em conformidade com as normas e padrões de segurança da informação trazidos pela Lei Geral de Proteção de Dados LGPD, aos preceitos legais que regem a responsabilidade sobre os dados gerados, armazenados, tratados e trafegados em ambiente desse município. Conforme destacado anteriormente, a LGPD estabelece que os Dados Pessoais tratados pelo Poder Público deverão ser mantidos em formato interoperável e estruturado para o uso compartilhado com seus diversos órgãos e esferas

2.12 Deste modo, resta justificada a necessidade da presente contratação para o alcance dos objetivos do projeto.

3. DESCRIÇÃO DA SOLUÇÃO

3.1. Levando-se em consideração a atual situação da estrutura de segurança da Unidade Municipal De Tecnologia Da Informação/ UMTI, foram especificadas as características de contratação de soluções e serviços de segurança digital integrados em plataforma única para proteção do ambiente computacional e seus ativos. A plataforma deverá contemplar, de maneira totalmente integrada, disponibilidade e capacidade de gestão, garantindo desempenho e proteção dos acessos aos dados e informações sensíveis dos sistemas e informações em custódia, hospedados e processados no ambiente da presente Unidade. Todas as soluções que compõem a Plataforma deverão ser interoperáveis entre si, permitindo uma gestão integrada de todas as soluções ofertadas. A Plataforma deverá contemplar os seguintes itens:

3.1.1. Solução de gestão centralizada de chaves criptográficas e criptografia;
3.1.2. Solução de Identificação e Classificação de Dados;
3.1.3. Solução de Gestão de Identidade e Acesso;
3.1.4. Solução de Prevenção de Vazamento de dados;
3.1.5. Solução de Gestão de senhas de alto privilégio;
3.1.6. Solução de Gestão e Correlação de eventos de segurança;
3.1.7. Solução de painel central de gerenciamento de indicadores de segurança;
3.1.8. Solução de Web Application Firewall;
3.1.9. Serviços de projeto e implementação;
3.1.10. Serviços de Treinamento;
3.1.11. Serviços de Operação Assistida.

3.2. Tabela de Composição de Itens

ITEM	DESCRIÇÃO	MÉTRICA	QUANT.
1	Console de Gerenciamento de Chaves Criptográficas	Licença Perpétua / Aquisição	2
2	Criptografia para Sistemas de Arquivos de Servidores	Licença Perpétua / Aquisição	2
3	Criptografia de Registros em Bancos de Dados via Aplicações Web	Licença Perpétua / Aquisição	5
4	Criptografia para Compartilhamento Seguro de Base de Dados	Licença Perpétua / Aquisição	1
5	Agentes para Gestão de Chaves de terceiros	Licença Perpétua / Aquisição	2
6	Módulo de Identificação e Classificação de dados.	Licença Subscrição (Mensalidade)	12
7	Solução de gestão de identidade e acesso.	Licença Subscrição (Mensalidade)	12

8	Solução de Prevenção de vazamento de dados.	Licença Subscrição (Mensalidade)	12
9	Solução de gestão de credenciais de alto privilégio	Licença Perpétua / Aquisição	1
10	Solução de Gestão e Correlação de eventos de segurança	Licença Subscrição (Mensalidade)	12
11	Painel Central de Gerenciamento de Indicadores de Segurança	Licença Subscrição (Mensalidade)	12
12	Solução de Web Application Firewall	Licença Subscrição (Mensalidade)	12
13	Manutenção e Garantia de Console de Gerenciamento de Chaves Criptográficas	Serviço mensal	12
14	Manutenção e Garantia para Criptografia para Sistema de Arquivos de Servidores	Serviço mensal	12
15	Manutenção e Garantia para Criptografia de Registros em Bancos de Dados via Aplicações Web	Serviço mensal	12
16	Manutenção e Garantia para Criptografia de Compartilhamento Seguro de Base de Dados	Serviço mensal	12
17	Manutenção e Garantia de Agentes de Gestão de Chave de terceiro	Serviço mensal	12
18	Manutenção e Garantia para Solução de gestão de credenciais de alto privilégio	Serviço mensal	12
19	Serviços de projeto e implementação;	Serviço	1
20	Treinamento	Serviço	1
21	Serviço de Operação Assistida	Serviço mensal	11

3.3. Vigência

3.3.1. O contrato terá vigência de 12 (doze) meses, a contar da data de assinatura do Contrato ou da última data da assinatura eletrônica registrada no Contrato. Podendo ser renovada até seu limite legal.

3.3.2. Durante o período de vigência das manutenções, estarão inclusas todas as atualizações necessárias para o perfeito funcionamento da solução.

4. DO PARCELAMENTO DO OBJETO

A solução a ser contratada trata-se de uma Plataforma Integrada de Segurança da Informação composta por soluções interoperáveis e serviços que possuem interdependência em sua operação, gestão e integração ao longo de seu uso e aplicação no ambiente computacional dessa administração, deste modo, o parcelamento do objeto torna-se inviável, pelas razões abaixo destacadas.

Do ponto de vista técnico, ao segmentar o objeto em diversas licitações ou lotes distintos não seria possível garantir a mitigação dos riscos associados ao vazamento de dados e ataques cibernéticos, uma vez que seriam contratadas diversas empresas para operar separadamente cada um dos módulos, sem nenhuma integração e interoperabilidade entre si, reduzindo assim o tempo de resposta em um eventual incidente.

De igual modo, na ocorrência de vazamento de dados ou ataque malicioso ao ambiente computacional dessa administração, não seria possível identificar e precisar qual módulo não teve seu funcionamento adequado ou não exerceu sua função de mitigar tais riscos, conferindo eventual transferência de responsabilidade entre diversas empresas contratadas que tentariam direcionar a falha aos demais módulos, dificultando e onerando a gestão contratual.

Acrescenta-se que a presente contratação não compreende somente o licenciamento de uma plataforma integrada, mas prevê a execução de serviços de operação assistida, instalação, integrações necessárias, configuração e manutenção, devendo a empresa contratada garantir o correto funcionamento de todas as soluções, formando um todo indissociável e indivisível, capaz de funcionar e operar de maneira conjunta.

É dever da administração analisar e pesar com razoabilidade e proporcionalidade a possibilidade do parcelamento ou não de um objeto, devendo considerar o ponto de vista técnico e econômico, sem prejuízo a competitividade e isonomia, haja vista que o mercado possui empresas integradoras capazes de fornecer o objeto em Plataforma integrada, contemplando todos os serviços necessários ao seu correto uso e funcionamento.

Do ponto de vista econômico e institucional, há que se considerar uma visão global do projeto, uma vez que o parcelamento trará, além dos inúmeros custos indiretos associados a ineficiência no uso e aplicação da solução e na gestão particionada de diversos contratos, o acesso de diversas empresas e agentes das contratadas ao ambiente de TI dessa administração, comprometendo o objetivo principal dessa licitação, que é justamente mitigar riscos associados ao vazamento de dados e incidente no campo da segurança da informação.

5. REQUISITOS TÉCNICOS E FUNCIONAIS:

5.1. Gerenciamento de Chaves Criptográficas e Criptografia – ITEM 1

5.1.1. A solução deve oferecer recursos para proteger e controlar o acesso a bancos de dados, arquivos e microserviços, além de poder proteger ativos que residem em nuvem, servidores virtuais, big data e servidores físicos;

5.1.2. A solução deverá prover uma console de gerenciamento composta por um conjunto integrado de produtos baseados em uma infraestrutura comum e extensível, com gerenciamento centralizado de políticas e de chaves;

5.1.3. A solução deverá prover uma console única que permita o gerenciamento centralizado de todos os agentes de criptografia, suas chaves criptográficas, políticas de configuração, publicação e controle de acesso dos dados a serem protegidos;

5.1.4. A console deverá possuir obrigatoriamente certificação FIPS 140-2, com no mínimo Nível 2, ou seguir um padrão de encriptação seguro, conforme padrão internacional reconhecidamente aceito, para garantir total segurança das chaves criptográficas;

5.1.5. A console de gerenciamento centralizado deverá suportar agentes para as funcionalidades que seguem:

5.1.5.1. Criptografia transparente – para criptografar, controlar o acesso ao dado e oferecer registros de auditoria de acesso aos dados sem impactar nas aplicações, base de dados ou infraestrutura onde quer que os servidores estejam instalados;

5.1.5.2. Integração com SIEM – suportar integração com os sistemas de gerenciamento de logs do mercado;

5.1.5.3. Segurança de microserviços - oferecer criptografia de dados, controle de acesso e registro de acesso ao dado com integração com ambientes Kubernetes;

5.1.5.4. Gerenciamento de chaves em nuvem múltipla – permitir custódia e controle de dados em ambiente de software como serviço (SaaS), relatório de acesso e eficiência no gerenciamento do ciclo de vida da chave em nuvem com o conceito Traga sua Própria Chave (BYOK);

5.1.5.5. Segurança de big data - criar isolamento em seus data lakes, mascarar dados confidenciais e controlar a segurança e a conformidade de usuários e administradores;

5.1.5.6. Tokenização e mascaramento de dados - reduzir os custos e o esforço necessários para cumprir com as políticas de segurança e normas regulatórias como o LGPD, GDPR entre outras;

5.1.5.7. Criptografia para aplicações – simplificar o processo de adição de criptografia em aplicações, por meio de APIs baseadas em padrões que potencializem operações criptográficas e de gerenciamento de chaves de alto desempenho;

5.1.6. O console deverá ser capaz de ser configurada em alta disponibilidade (HA) com um nó primário e um nó secundário;

5.1.7. Deverá apoiar a incorporação de vários consoles adicionais para fins de configuração de esquemas de tolerância a falhas multinível;

5.1.8. Os agentes instalados nos servidores deverão operar de forma autônoma não causando impacto em caso de perda de comunicação com a console;

5.1.9. Os agentes ou equivalentes deverão realizar a criptografia e a rotação de chaves sem causar indisponibilidade nos servidores e aplicações;

5.1.10. Cada console deverá ter a escalabilidade para suportar o crescimento;

5.1.11. Detalhes da chave de criptografia não deverão ser divulgados para usuários do sistema para que o algoritmo de criptografia esteja protegido dos usuários da plataforma. Estes deverão ser armazenado de forma segura em um dispositivo dedicado aos serviços de segurança dentro do console;

5.1.12. Não serão aceitas soluções de fabricantes distintos para os itens que compõem a solução de gestão de chaves criptográficas e demais criptografias;

5.1.13. A console deverá possuir capacidade de gerenciar chaves criptográficas padrão KMIP (Key Management Interoperability Protocol);

5.1.14. Deverá ser compatível com APIs PKCS (Public Key Cryptography Standards) # 11, JCE (Java Cryptography Extension), Microsoft CNG (Criptography API Next Generation) e Microsoft Key Extensible Management.

5.1.15. Deverá ser capaz de oferecer suporte a certificados digitais (X. 509) PKCS # 7, PKCS # 8 e PKCS # 12, chaves de criptografia simétrica (algoritmos 3DES, AES128, AES256, ARIA128 e ARIA256) e assimétrica (algoritmos RSA1024, RSA2048, RSA3072, RSA4096 e Elliptic curve);

5.1.16. Deverá ser escalável para oferecer suporte a gerenciamento de agente de vários serviços em uma estrutura de multitenant e com suporte a configuração de segurança de vários domínios. Para isso, deverá possibilitar configurar diferentes chaves criptográficas de acordo com cada área de operação, se necessário;

5.1.17. A console deverá possibilitar gerenciamento via interface Web além de comandos (CLI) e API (REST);

5.1.18. Deverá requerer autenticação de usuário e senha e, opcionalmente, com certificados digitais;

5.1.19. Deverá ser capaz de configurar cópias de backup de suas configurações automaticamente ou manualmente;

5.1.20. Requerimentos complementares:

- 5.1.20.1. Deverá suportar usuários múltiplos;
- 5.1.20.2. Deverá possuir suporte comprovado para até 1 milhão de chaves criptográficas;
- 5.1.20.3. Deverá possibilitar cluster para alta disponibilidade (HA);
- 5.1.20.4. Deverá possuir toolkit e interface de programação;
- 5.1.20.5. Deverá suportar Integração com infraestrutura de autenticação existente, com fácil configuração;
- 5.1.20.6. Deverá possuir API RESTful;

5.1.21. Instalação:

- 5.1.21.1. A solução deverá ser instalada em hardware ou software com certificação FIPS 140-2 com no mínimo Nível 2, ou compatível.

5.2. Criptografia para Sistemas de Arquivos de Servidores – ITEM 2

5.2.1. Deverá oferecer controle de acesso de usuários, incluindo usuários privilegiados, e registro detalhado de auditoria de acesso visando atender aos requisitos de conformidade e práticas recomendadas para proteção de dados;

5.2.2. Deverá prover criptografia de servidor de arquivo (dado não estruturado) para dados em repouso com gerenciamento centralizado de chaves;

5.2.3. O processo de criptografia deverá ser executado por agentes ou equivalentes que deverão ser instalados nos servidores de arquivos;

5.2.4. O agente ou equivalente deverá residir no sistema operacional ou na camada de dispositivo, e a criptografia e a descriptografia deverão ser transparentes para todos os aplicativos executados acima dela;

5.2.5. Os agentes deverão oferecer suporte a sistemas operacionais Microsoft, Linux e AIX;

5.2.6. Deverá ser compatível com servidores físicos e versões virtualizadas;

5.2.7. O agente ou equivalente deve ter certificação FIPS 140-2 Nível 1, ou compatível;

5.2.8. Sua implementação não deverá exigir qualquer alteração no servidor de arquivo ou processo para manuseio do dado pelo usuário final;

5.2.9. Deverá ser capaz de criptografar arquivo, volume ou diretório desses servidores de forma que eles possam proteger informações não estruturadas;

5.2.10. O agente ou equivalente deve fazer a criptografia e a rotação/mudança de chaves com dado em uso, ou seja, sem indisponibilidade nos servidores;

5.2.11. Estes devem usar os recursos de aceleração disponíveis, como o AES-NI. A implementação destes não deve gerar carga incremental superior a 5% (cinco por cento);

5.2.12. Os agentes deverão registrar e rastrear o acesso dos usuários de sistema aos arquivos e ser capaz de bloquear ou restringir este acesso;

5.2.13. As políticas de controle de acesso deverão ser aplicadas aos usuários privilegiados do sistema e estes não deverão possuir autoridade para desfazer a política de acesso na tentativa de elevar novamente seu privilégio;

5.2.14. Essas diretivas deverão permitir ser baseadas em usuário, processo e tipo de arquivo;

5.2.15. As políticas deverão ser aplicadas aos usuários locais, ou igualmente integradas no AD ou no LDAP;

5.2.16. Os agentes deverão ter a capacidade de armazenar chaves criptográficas em memória para que eles não exijam conectividade com a console de gerenciamento para poder aplicar processos de criptografia e descriptografia;

5.2.17. Os registros (logs) de atividade do usuário deverão ter a capacidade de ser enviado para uma solução de SIEM através de um servidor de syslog ou no formato CEF, em tempo real e nativamente;

5.2.18. A solução deverá suportar ambiente em nuvem, tais como AWS, Azure, IBM, Oracle Cloud e Google Cloud pelo menos;

5.2.19. A solução devera oferecer integração com Kubernetes para ambientes de microserviços;

5.2.20. Deverá registrar todas as tentativas de acesso de usuários, aplicativos e processos;

5.2.21. Deverá possuir políticas de acesso para identificar qual dado foi acessado, quem o acessou e o local que foi acessado;

5.2.22. Deverá permitir que usuários privilegiados executem seu trabalho sem acesso à informação em texto não criptografado;

5.2.23. Deverá ser compatível com os sistemas operacionais:

- 5.2.23.1. Windows Server 2016, 2019 R2 (64 bits);
- 5.2.23.2. Red Hat e CentOS 7.5-8.0, SLES 12 SP4, SLES 12 SP5, SLES 15, Ubuntu 16, Ubuntu 18 e Ubuntu 20;
- 5.2.23.3. Oracle Linux.

5.3. Criptografia de Registros em Bancos de Dados via Aplicações Web – ITEM 3

5.3.1. Permitir a toquenização, independentemente do tipo de banco de dados, com mascaramento dinâmico, para promover a anonimização de dados, incluindo dados pessoais, seja no Data Center, ambiente de big data ou Nuvem.

5.3.2. Possuir servidores de token escalável;

5.3.3. Comunicação via TLS autenticado mutuamente;

5.3.4. Interface REST API com chamadas individuais e em lote;

5.3.5. Permitir geração de Tokens Aleatórios;

5.3.6. Compatível com FPE FF1, Tokens FF3;

5.3.7. Oferecer integração para SAP Data Custodian;

5.3.8. Permitir Mascaramento Dinâmico ou Estático de Dados;

5.3.9. Gerenciamento de chaves e políticas;

5.3.10. Suporte AD / LDAP;

5.3.11. Suporte a dados numéricos e alfanuméricos;

5.3.12. Permitir a criação de tokens em formatos numéricos, de texto e de data para aplicativos únicos ou múltiplos;

5.3.13. Permitir utilizar grupos de usuários LDAP para decidir quais informações são exibidos para grupos específicos;

5.3.14. Suportar servidor de tokens no formato virtual de sua escolha: OVF, ISO, Microsoft Azure Marketplace ou Amazon AMI;

5.3.15. Suportar operação em Proxy para interceptação de chamadas REST API entre aplicações web e tokenização de dados;

5.3.16. O Proxy deverá ser ‘transparente” para as aplicações web sem a necessidade de alterar o código das aplicações;

5.3.17. Restringir o acesso a ativos confidenciais sem alterar os esquemas do banco de dados, sem interrupções;

5.3.18. Proteger dados em trânsito e em repouso;

5.3.19. Mascarar os dados em ambiente de desenvolvimento, teste e terceirizados com acesso ao banco de dados;

5.3.20. Deverá oferecer funções para uso de tokenização de dados em banco de dados;

5.3.21. As funções para banco de dados devem ser compatíveis para Banco de dados tradicionais como Oracle, Microsoft SQL Server, MySQL, PostgreSQL e para tecnologias Big data como Hive, Impala e Hbase;

5.3.22. Proteger DBAs, administradores de sistema, root, e usuários mal-intencionados com acesso direto ao banco;

5.4. Criptografia para Compartilhamento Seguro de Bases de Dados – ITEM 4

5.4.1. Este agente deverá permitir o mascaramento dos dados sensíveis para permitir o compartilhamento seguro com terceiros, ambientes de teste, ambientes de desenvolvimento e outros casos de uso aplicáveis;

5.4.2. O funcionamento deverá ser baseado em tabela e/ou coluna;

5.4.3. A solução deverá ser customizável e de alta performance;

5.4.4. A solução deverá suportar, pelo menos, as operações de criptografia (tokenização) e descriptografia (detoquenização) de tabelas e / ou colunas;

5.4.5. A solução deverá ser "transparente" para a aplicação ou banco de dados com acesso via conexão JDBC, sem a necessidade de requerer alterações ou instalações adicionais no servidor de banco de dados;

5.4.6. A solução deverá suportar, pelo menos, arquivo CSV, Oracle, Microsoft SQL Server, SAP HANA e IBM DB2;

5.4.7. A solução deverá permitir replicação de arquivo para arquivo, banco de dados para banco de dados, arquivo para banco de dados e banco de dados para arquivo;

5.4.8. Pelo menos os seguintes modelos deverão ser suportados: Standard AES Encryption, Batch random Tokenization e Batch FPE FF3/FF1;

5.5. Agente para Gestão de Chaves de terceiro – ITEM 5

5.5.1. Ser capaz de centralizar o gerenciamento de chaves de aplicativos de terceiros que usam criptografia nativa, tal como bancos de dados;

5.5.2. O agente deve ter a capacidade de conectar-se com os aplicativos por meio de interfaces padrão e fornecer acesso às funções robustas de gerenciamento de chaves;

5.5.3. Prover simplificação e redução da carga operacional por meio do gerenciamento centralizado de chaves;

5.5.4. Elevar o nível de segurança pela separação das chaves de criptografia das aplicações, banco de dados, storage e etc;

5.5.5. Gerenciar chave utilizando soluções de hardware ou software com padrões e requisitos da certificação FIPS ou equivalente;

5.5.6. Suportar o protocolo de Interoperabilidade de Gerenciamento de Chaves (KMIP / PKCS) que é o padrão do setor para troca de chaves de criptografia entre clientes (usuários principais) e um servidor (armazenamento de chaves). A padronização simplifica o gerenciamento de chaves externas;

5.5.7. Garantir a custódia de chaves para, pelo menos: Oracle TDE, SQL TDE, Nutanix, VMWare, Cisco, Netapp, Certificados, Aplicações desenvolvidas em casa, outros volumes compatíveis;

5.6. Solução de Identificação e Classificação de Dados - ITEM 6

5.6.1. A solução deverá possibilitar a descoberta de dados, em ambiente de dados estruturados e não estruturados, armazenados em diferentes repositórios, tais como:

5.6.1.1. Servidores de Arquivos;

5.6.1.2. Banco de Dados;

5.6.1.3. Big data;

5.6.1.4. Estações de trabalho;

5.6.2. A solução deve permitir, através de interface única, realizar o levantamento e entendimento dos dados existentes, sua localização e riscos associados, permitindo:

5.6.3. Atender aos requisitos de privacidade;

5.6.4. Obter visibilidade sobre os dados que estão em risco de exposição;

5.6.5. Suportar a criação de plano de privacidade e proteção de dados;

5.6.6. A solução ofertada deverá possibilitar, pelo menos, quatro níveis de classificação de dados por padrão:

5.6.6.1. Restrito;

5.6.6.2. Privado;

5.6.6.3. Interno;

5.6.6.4. Público;

5.6.7. A solução deve atribuir pontuações de risco que permitam identificar o nível de sensibilidade dos dados, como arquivos e bancos de dados, agregando os seguintes parâmetros:

5.6.7.1. Nível de proteção;

5.6.7.2. Quantidade de elementos encontrados;

5.6.7.3. Localização;

5.6.7.4. Quantidade de dados confidenciais;

5.6.8. As pontuações de risco devem permitir identificar os dados com maior exposição e permitir priorizar medidas de proteção;

5.6.9. A solução deve suportar ambientes:

5.6.9.1. Armazenamento local em Hard Disk e Memória dos computadores;

5.6.10. Armazenamentos em rede:

5.6.10.1. Compartilhamento Windows CIFS e SMB;

5.6.10.2. Unix File System NFS;

5.6.11. Bancos de Dados:

5.6.11.1. IBM DB2;

5.6.11.2. Oracle;

5.6.11.3. SQL;

5.6.11.4. Big Data:

5.6.11.5. Clusters Hadoop

5.6.12. A solução deve suportar os seguintes tipos de arquivos:

5.6.12.1. Banco de Dados;

5.6.12.2. Access;

5.6.12.3. Dbase;

5.6.12.4. SQLite;

5.6.12.5. MSSQL MDF & LDF;

5.6.12.6. MySQL

5.6.13. Arquivos de Imagens:

5.6.13.1. BMP;

5.6.13.2. FAX;

5.6.13.3. GIF;

5.6.13.4. JPG;

5.6.13.5. PDF;

5.6.13.6. PNG;

5.6.13.7. TIF;

5.6.14. Arquivos Compactados:

5.6.14.1. bzip2;

5.6.14.2. Gzip (todos os tipos);

5.6.14.3. TAR;

5.6.14.4. Zip (todos os tipos);

5.6.15. Microsoft Backup:

5.6.15.1. Microsoft Binary / BKF;

5.6.16. Microsoft Office:

5.6.16.1. v5;

5.6.16.2. v6;

5.6.16.3. 95;

5.6.16.4. 97;

5.6.16.5. 2000;

5.6.16.6. XP;

5.6.16.7. 2003 e superiores;

5.6.17. Open Source:

5.6.17.1. Star Office;

5.6.17.2. Open Office;

5.6.18. Padrões abertos:

5.6.18.1. PDF;

5.6.18.2. HTML;

5.6.18.3. CSV;

5.6.18.4. TXT;

5.6.19. A solução deve classificar os dados como:

5.6.19.1. Dado pessoal;

5.6.19.2. Dados financeiros, com base em modelos integrados ou técnicas de classificação;

5.6.20. Deve possibilitar a identificação de informações padronizadas do Brasil, tais como:

5.6.20.1. Registro Geral (RG);

5.6.20.2. Cadastro de Pessoa Física (CPF);

5.6.20.3. Carteira Nacional de Habilitação (CNH);

5.6.20.4. Passaporte;

5.6.21. A solução deve permitir a inclusão de modelos de políticas (descoberta e classificação) específicas para LGPD;

5.6.22. A solução deve fornecer relatórios detalhados para demonstrar conformidade com a Lei Geral de Proteção de Dados (LGPD);

5.6.23. A solução deve possibilitar a classificação de dados utilizando:

5.6.23.1. Expressões Regulares (Regex);

5.6.23.2. Padrões (Patterns);

5.6.23.3. Algoritmos;

5.6.23.4. Contexto;

5.6.24. A solução deve possibilitar ser implementada “com” ou “sem” softwares instalados;

5.6.25. A solução ofertada deverá permitir total integração com as soluções de gestão de chaves criptografia especificadas neste termo referência.

5.6.26. A solução deve oferecer as seguintes características funcionais:

5.6.26.1. Definir as políticas de privacidade de dados, locais e perfis de varredura e de classificação;

5.6.26.2. Localizar dados estruturados e não estruturados, através de toda a organização em ambientes big data, banco de dados e sistema de armazenamento de arquivos;

5.6.26.3. Classificar dados pessoais e sensíveis, baseado em modelos pré-configurados e técnicas de classificação;

5.6.26.4. Entender a natureza do dado e seus riscos, oferecendo visualizações;

5.6.26.5. Gráficos e relatórios de análise de risco, status e alertas durante todo o ciclo de vida do dado.

5.6.27. A solução deverá ser dimensionada para executar varreduras em volumes de 50TB (Cinquenta TeraBytes);

5.7. Solução de Gestão de Identidade e Acesso - ITEM 7

5.7.1. A solução deverá ser dimensionada para 2500 (dois mil e quinhentos) usuários;

5.7.2. Garantir 99.999% de disponibilidade para acesso remoto;

5.7.3. Garantir visibilidade e gerenciamento de todos os serviços e usuários do MFA;

5.7.4. A solução de MFA deve suportar diversos fatores de autenticação, tais como:

5.7.4.1. Soft Token;

5.7.4.2. Hard Token

5.7.4.3. Mobile App;

5.7.4.4. SMS;

5.7.4.5. SmartCard;

5.7.4.6. PIV;

5.7.4.7. FIDO;

5.7.4.8. Certificados Digitais;

5.7.4.9. Push;

5.7.5. Deve conter políticas granulares para esses tokens, de acordo com a necessidade e adequação de cada negócio;

5.7.6. Deve suportar mais de um tipo de token para o usuário;

5.7.7. A Solução de MFA de suportar diversos sistemas operacionais e identificar dentro da ferramenta:

5.7.7.1. Windows 7/8/10;

5.7.7.2. MAC OS.

5.7.8. A Solução deve também suportar dispositivos móveis:

5.7.8.1. Android (Diversas versões);

5.7.8.2. IOS;

5.7.9. A Solução deve ser capaz de identificar o dispositivo pelo sistema operacional e criar políticas de acordo com a necessidade do negócio baseada em cada SO, incluso sistemas operacionais de dispositivos móveis;

5.7.10. A Solução deverá suportar Auto registro. Uma página na qual o próprio usuário poderá solicitar um token, avisar que perdeu, solicitar um outro tipo de token, caso tenha esquecido ou perdido o token original;

5.7.11. A solução deverá suportar Geolocalização, e criar políticas de acordo com esse perfil;

5.7.12. Gerenciar do Risco através de políticas de contexto, tais como tipo de rede, tipo de sistema operacional, tipo de dispositivo e geolocalização;

5.7.13. A solução deverá verificar o tipo de conexão, anonimizada ou não e ser possível criar perfis de acordo;

5.7.14. A solução deve suportar integração com LDAP e AD;

5.7.15. A solução de prover relatórios de auditoria e poder exportar os dados;

5.7.16. Deve suportar integração com SIEM;

5.7.17. A solução deve ser capaz de criar políticas de acordo com cada perfil, grupo de usuários;

5.7.18. A solução deve ser capaz de criar políticas de acordo com cada aplicação;

5.7.19. A solução deve ter a opção de verificar se já é um dispositivo conhecido;

5.7.20. A solução deverá permitir Single Sign on;

5.7.21. Mesmo com o Single Sign on, deverá ser possível criar políticas de verificação em cada aplicação;

5.7.22. A Solução deve conter um dashboard informando os acessos por aplicação (Acessos validos e negados);

5.7.23. A solução deve conter um dashboard informando os acessos por políticas (Acessos Validos e negados);

5.7.24. A solução deve prover informações a respeito de qual IP está sendo feita a autenticação, e qual método utilizado para o duplo fator de autenticação;

5.7.25. A Solução deve prover para o usuário final, um portal, consolidando todas a aplicações nas quais ele tem acesso;

5.7.26. Suportar integrações via Radius;

5.7.27. Suportar integrações via SAML 2.0;

5.7.28. A solução deverá suportar as 27 (vinte e sete) bases de usuários de aplicações legadas, que se utilizam de sistemas de autenticação diferentes, sejam elas:

5.7.28.1. SQL;

5.7.28.2. LDAP

5.7.28.3. AD

5.7.28.4. ODBC

5.7.28.5. Lotus

5.7.28.6. Novell

5.7.28.7. Outros via mapeamento de campos

5.7.29. A solução deverá se adequar às aplicações legadas, utilizando-se de meios próprios, mesmo que isso incorra no desenvolvimento e adaptação;

5.7.30. A solução deverá suportar meios para integração com as aplicações legadas, fornecendo um conjunto de bibliotecas (API e SDK);

5.7.31. A solução deve oferecer integração com as aplicações legadas minimamente com as funcionalidades de duplo fator de autenticação (MF2) e rastreabilidade (data e hora de entrada e saída);

5.8. Solução de Prevenção de Vazamento de Dados - ITEM 8

5.8.1. A solução deverá ser dimensionada para 3100 (três mil e cem) usuários;

5.8.2. Deverá ser capaz de detectar e identificar dados acessados pelo usuário em trânsito ou dentro da rede e ser armazenado localmente ou em um compartilhamento de rede;

5.8.3. Deverá ser gerenciada por uma console separadamente das estações de trabalho;

5.8.4. Deverá fornecer ações capazes de relatar um incidente, bloquear o acesso do usuário aos dados e colocar e-mails em quarentena que contenham dados confidenciais;

5.8.5. Deverá, por meio de agentes instalados, permitir o controle dos dados em uso, como ações do usuário relacionadas à cópia de informações, impressão de arquivos classificados e captura de tela (Print Screen);

5.8.6. O agente deverá utilizar regras para proteger dados confidenciais contra vazamento nos seguintes vetores:

5.8.6.1. Software de clipboarding (copiar e colar);

5.8.6.2. Aplicações em nuvem;

5.8.6.3. E-mail;

5.8.6.4. Compartilhamento de rede;

5.8.6.5. Impressão;

5.8.6.6. Captura de tela;

5.8.6.7. Aplicativos e navegadores específicos;

5.8.6.8. Postagens na Web;

5.8.7. Deverá ser capaz de restringir as regras de proteção de dados a grupos de usuários do serviço de diretórios;

5.8.8. Deverá ser capaz de restringir as regras de proteção de dados a grupos de máquinas ou equipamentos que fazem parte da mesma faixa de endereços IP com agentes instalados;

5.8.9. Deverá ser capaz de restringir as regras de proteção de dados com base no funcionamento do sistema operacional, minimamente:

5.8.9.1. Windows 7 e superior,

5.8.9.2. Windows Server 2008 R2 e superior;

5.8.10. Deverá ser capaz de replicar conteúdo sensível que tenha violado uma regra de proteção de dados em sua totalidade;

5.8.11. Deverá permitir a execução de políticas independentemente da conexão do usuário;

5.8.12. Deverá utilizar técnicas e dicionários de reconhecimento de padrões de texto predefinidos;

5.8.13. As políticas deverão abranger Classificação, Rastreamento, Monitoramento e Proteção;

5.8.14. Deverá permitir a configuração de classificações da informação, pelo menos:

5.8.14.1. Confidencial, Restrita e Pública;

5.8.15. Deverá permitir para cada classificação, que as informações a serem protegidas possam ser definidas. Os métodos de definição devem incluir:

5.8.15.1. Padrões Avançados (Exemplo: Regex);

5.8.15.2. Dicionários;

5.8.15.3. Arquivos TrueType;

5.8.15.4. Origem ou Destino;

5.8.15.5. Grupos de aplicativos;

5.8.16. Deverá permitir que grupos de aplicação sejam adicionados à solução como critério de classificação de dados;

5.8.17. Deverá possuir método de identificação e rastreamento de conteúdo;

5.8.18. Deverá permitir que classificações sejam baseadas em pelo menos as seguintes informações de contexto do arquivo:

5.8.18.1. Aplicação web da qual o arquivo se originou;

5.8.18.2. Compartilhamento de rede da qual foi copiada;

5.8.18.3. Arquivos baixados de serviços de nuvem;

5.8.19. Deverá ser capaz de varrer todos os arquivos armazenados em um determinado repositório para proteger conteúdo classificado;

5.8.20. Deverá permitir a classificação manual dos arquivos, adicionando etiquetas (Tags) e permitindo seu rastreamento;

5.8.21. Deverá ter a capacidade de criar regras para identificar conteúdo sensível e tomar uma ação específica;

5.8.22. Deverá permitir a criação de regras para controlar a distribuição não autorizada de dados classificados;

5.8.23. Deverá conter mecanismos de proteção que impeçam a desinstalação do agente localmente;

5.8.24. Deverá permitir que o agente seja executado no modo de segurança no sistema operacional Windows;

5.8.25. Deverá ter classificações definidas por padrão, por exemplo: EAR, HIPAA,PCI, PHI, SOX etc.

5.8.26. Deverá ter a capacidade de identificar informações confidenciais com base em padrões avançados (expressão regular);

5.8.27. Deverá permitir o uso de propriedades de documentos do Microsoft Office para classificá-lo;

5.8.28. Deverá permitir a definição de classificação com base na origem ou destino, suportando pelo menos:

5.8.28.1. Aplicação;

5.8.28.2. Grupo de Usuários;

5.8.28.3. Compartilhamento de rede;

5.8.28.4. Deverá possuir modelos definidos por fabricante;

5.8.29. Deverá, além dos modelos já incluídos na solução, criar livremente padrões e dicionários avançados para identificar informações confidenciais nas estações de trabalho;

5.8.30. Deverá permitir a inclusão de documentos que não devem ser detectados pela solução (Whitelist);

5.8.31. Deverá ser capaz de procurar informações confidenciais armazenadas localmente e na nuvem;

5.8.32. Deverá identificar o local onde os dados confidenciais são armazenados;

5.8.33. Deverá permitir a visualização de todos os dados indicados na varredura através da console intuitivo;

5.8.34. Deverá suportar classificação de conteúdo, tais como:

5.8.34.1. Cloud Store;

5.8.34.2. Documentos do Microsoft Office;

5.8.34.3. Arquivos da Adobe;

5.8.34.4. Arquivos compactados;

5.8.35. Deverá permitir o agendamento de tarefas periódicas para a varredura do repositório;

5.8.36. Deverá permitir que o administrador configure varreduras distintas;

5.8.37. A varredura de inventário deverá fornecer uma visão geral dos tipos de arquivos em cada repositório, executando apenas:

5.8.37.1. Coleta de metadados;

5.8.37.2. Classificação dos metadados em diferentes tipos de conteúdo e análise de atributos, como tamanho do arquivo, localização de armazenamento e extensão;

5.8.38. A varredura de classificação deverá permitir entender quais tipos de dados existem em repositórios;

5.8.39. Deverá comparar o conteúdo analisado com classificações estabelecidas, por exemplo, padrões de texto ou dicionários;

5.8.40. A varredura de remediação deverá permitir encontrar dados que violem uma determinada política de sensibilidade de dados estabelecida;

5.8.41. Deverá ter a capacidade de realizar a descoberta em agentes distribuídos em estações de trabalho, permitindo a descoberta de conteúdo em:

5.8.42. Sistema de arquivos local em estações de trabalho com sistema operacional Windows;

5.8.43. Servidor de arquivos;

5.8.44. A solução através do agente deverá permitir que a detecção de um arquivo sensível seja automaticamente classificada pela solução;

5.9. Solução de Gestão de Senhas de Alto Privilégio - ITEM 9

5.9.1. Será utilizada para armazenamento seguro e controle de credenciais não pessoais e privilegiadas em Servidores Linux/Unix, Windows, Sistemas, Aplicações Web, Bancos de Dados, Estações de Trabalho e Dispositivos de Rede;

5.9.2. Deverá prover autenticação transparente no sistema-alvo ou dispositivo de rede. A solução deverá iniciar uma sessão injetando diretamente as credenciais na tela de login e servindo como um proxy para a sessão entre o usuário e o sistema-alvo, de forma que a senha não seja exposta ao solicitante do acesso;

5.9.3. Gerar vídeos ou logs de textos das sessões realizadas através da solução, armazenados em repositório seguro, criptografado e protegido contra qualquer alteração que comprometa a integridade dessas evidências;

5.9.4. Deverá ser baseada em appliance físico ou virtual com banco de dados proprietário e embarcado, a fim de garantir maior segurança e melhor desempenho da solução;

5.9.5. Possibilitar gerenciamento e utilização da solução através de interface Web;

5.9.6. Deverá ser compatível com os principais navegadores de mercado;

5.9.7. Deverá permitir segregação de funções, baseado em perfis de acesso;

5.9.8. Permitir login dos usuários da solução utilizando dois fatores de autenticação;

5.9.9. Permitir que dois ou mais usuários solicitarem acesso a mesma conta privilegiada e/ou genérica, sem comprometimento da rastreabilidade;

5.9.10. Permitir aos administradores se autenticarem na interface de gerência da solução através de certificado digital;

5.9.11. A interface Web deverá suportar a utilização de certificados digitais válidos pela ICP-Brasil e certificados auto assinados gerados pela própria solução;

5.9.12. Ser capaz de operar como proxy de conexões via SSH/TELNET para qualquer dispositivo gerenciado, sem a necessidade de abertura de um Terminal Service;

5.9.13. A solução deverá prover conexões RDP controladas;

5.9.14. Autenticar de forma confiável todas as requisições de senhas realizadas pela solução, com a finalidade de impedir que qualquer usuário ou código malicioso tenha acesso ao repositório de senhas;

5.9.15. Toda a transmissão de dados entre os componentes da solução deverá ser criptografada;

5.9.16. Sobre a utilização de padrões criptográficos por determinadas funcionalidades, a solução deverá atender aos seguintes requisitos:

5.9.16.1. Utilizar algoritmo AES-256 para criptografia do tráfego de informações;

5.9.16.2. Para operações de autenticação e de acordo de chave de sessão, deve permitir a utilização de algoritmos dos sistemas de criptografia de chave pública RSA, Google Autenticator ou ECC;

5.9.16.3. Para os algoritmos do sistema de criptografia RSA, deve permitir a utilização de chaves;

5.9.17. A solução deverá ser compatível com os seguintes sistemas/aplicações:

5.9.17.1. Sistemas Operacionais: Windows Server 2008 e superiores, Red Hat Enterprise Linux 6 ou superiores;

5.9.17.2. Aplicações Windows: Contas de serviço englobando contas de serviço do SQL server em cluster, tarefas agendadas, pools de conexão do IIS, COM+, usuário anônimo do IIS, serviços de Cluster;

5.9.17.3. Sistemas Gerenciadores de Banco de Dados: Oracle, MSSQL, MySQL;

5.9.17.4. Appliances de Segurança: CheckPoint, Fortinet, Cisco, IBM, SourceFire e Imperva;

5.9.17.5. Dispositivos de redes: Cisco, D-Link, HP, 3com, Alcatel, Foundry, Brocade e ARUBA;

5.9.17.6. Aplicações: WebLogic, JBOSS, Tomcat, Peoplesoft, Oracle Application Server, Apache e IIS;

5.9.17.7. Serviços de Diretórios: Active Directory (AD) e OpenLDAP;

5.9.17.8. Possuir integração nativa com soluções de SIEM/Syslog;

5.9.17.9. Possuir workflow de aprovação para uso de credenciais;

5.9.17.10. Oferecer armazenamento e consulta de logs que forneçam ao menos, as seguintes informações:

5.9.17.11. Identificação do usuário que realizou determinado acesso a um dispositivo;

5.9.17.12. Identificação de quem aprovou o acesso do usuário;

5.9.17.13. Data e hora do acesso realizado e das ações que o usuário realizou no dispositivo remoto;

5.9.18. Deverá prover, ao menos, os seguintes filtros para a recuperação de logs:

5.9.18.1. Usuário;

5.9.18.2. Sistema-alvo acessado

5.9.18.3. Tipo de atividade

5.9.18.4. Intervalo de tempo (data/hora/minuto inicial e final)

5.9.19. A solução deverá vir acompanhado de todas as licenças de software ou hardware necessárias para atendimento das funcionalidades da solução;

5.9.20. Deverá disponibilizar os Templates de troca de senha de forma que possam ser abertos, editáveis e auditáveis;

5.9.21. A solução deverá não deverá depender de sistema operacional externo e/ou banco de dados que gerem a necessidade de licenças adicionais de outros fabricantes.

5.9.22. A solução deverá possibilitar a configuração em cluster de contingência, alta disponibilidade (HA) ou recuperação de desastres (DR);

5.9.23. A solução deverá possibilitar a configuração do backup da solução e seus dados conforme Política de Backup.

5.9.24. A solução deverá exibir opções de Gráficos e Dashboards para operação e gestão da ferramenta;

5.9.25. A solução deverá estar aderente às Normas ISO/IEC 27.001.

5.9.26. Gerenciar todo o ambiente sem a necessidade de instalação de agentes ou qualquer software nos sistemas-alvos ou dispositivos de rede;

5.9.27. Possibilitar a geração automática de senhas de alta complexidade de acordo com as regras de cada tecnologia e Política de Segurança;

5.9.28. Realizar a troca automática das senhas, em horário programado, após terem sido liberadas para uso ou por vencimento de prazo;

5.9.29. Oferecer a possibilidade de gerenciar senhas privilegiadas em aplicações e integração com sistemas legado;

5.9.30. Prover área de transferência segura, de forma que o solicitante possa visualizar a senha ou copiá-la para a tela de login do sistema-alvo;

5.9.31. Executar a liberação ou revogação de todos os acessos de uma determinada credencial de maneira automatizada e imediata;

5.9.32. Deverá provisionar usuários locais em servidores Linux/Unix, Windows ou dispositivos de rede;

5.9.33. A solução deverá notificar, via e-mail ou SMS, novas solicitações de aprovação de acesso aos respectivos responsáveis pelas credenciais;

5.9.34. Permitir o monitoramento on-line do uso das contas e desligamento da sessão;

5.9.35. Apresentar recurso para acesso de emergência às contas, ou seja, permitirá acesso a ativos protegidos de forma emergencial, sem a necessidade de aprovação prévia em contas no qual o usuário não teria acesso, sem perda de rastreabilidade;

5.9.36. Deverá oferecer a funcionalidade de "Discovery" para realizar busca de novos servidores, elementos de rede e bancos de dados, sendo capaz de levantar automaticamente as contas criadas nesses novos dispositivos;

5.9.37. Oferecer a possibilidade de bloqueio de comandos específicos, com opção de interromper a sessão caso o usuário execute um comando indevido;

5.9.38. A solução deverá buscar por comandos específicos executados pelo usuário através de linha de comando em logs ou sessões gravadas;

5.9.39. A solução deverá possibilitar a configuração de alertas imediatos quando realizados determinados comandos por usuários privilegiado;

5.9.40. Oferecer a possibilidade de geração de relatórios baseados nos logs e exportá-los;

5.9.41. A solução deverá possuir mecanismo para exportar arquivo com as últimas senhas para repositório remoto, de forma criptografada e protegida por senha para recuperações no caso de falha total da solução;

5.9.42. Deverá utilizar tecnologia de restrição e autenticação que inclua Assinatura Digital (Hash), Path e endereço IP do host a serem acessados pela solução;

5.9.43. Oferecer a possibilidade de comunicação com os serviços de diretório via protocolo LDAPS;

5.9.44. Oferecer a possibilidade de implementação SNMP sobre IPv6;

5.9.45. Implementar a especificação IETF RFC 2460, referente ao protocolo IPv6;

5.9.46. Oferecer a possibilidade de implementar a MIB II, conforme RFC 1213;

5.9.47. Suportar sincronização do relógio interno via protocolo NTP e atualização automática do horário de verão com suporte e customização local;

5.9.48. Deverá controlar a elevação de privilégio em estações de trabalho;

5.9.49. Oferecer a possibilidade de mapear compartilhamentos de rede com um usuário administrador, diferente do usuário logado na máquina.

5.9.50. A solução deverá ser dimensionada para:

5.9.50.1. Usuários que se utilizarão da solução para acesso às credenciais de alto privilégio: 20 (vinte) usuários;

5.9.50.2. Quantidade de servidores: 120 (cento e vinte);

5.9.50.3. Quantidade de dispositivos de rede: 20 (vinte);

5.9.50.4. Servidores de banco de dados: 10 (dez);

5.9.50.5. Quantidade de sessões concorrentes: 12 (doze);

5.10. Solução de Gestão e Correlação de eventos de segurança - ITEM 10

5.10.1. Solução deve ser entregue em formato de software como serviço (SaaS -Software As A Service) com acesso principal em nuvem no Brasil;

5.10.2. Solução deve permitir conexão com interfaces espelhadas do vSwitch e switch físico para receber os pacotes que transitam pela rede;

5.10.3. A solução deve fazer correlacionamento de eventos tanto de ambientes local como ambientes em nuvem;

5.10.4. A solução deve capturar eventos de servidores através de uso de agente em maquinas e via sensores (coletores) espalhados na rede.

5.10.5. A solução deve permitir recebimento de eventos de dispositivos e permitir o uso de plug-ins para tradução dos arquivos de log de forma que a solução consiga ler e relacionar com outros eventos coletados ou recebidos;

5.10.6. A solução deve oferecer um serviço de desenvolvimento de novos plug-ins para importação de log de soluções que não estejam na lista de soluções já conhecidas do fabricante.

5.10.7. A solução deverá ter, no mínimo, 350 plugins pré-configurados em sua biblioteca;

5.10.8. Deverá prover um portal para solicitar a criação de novos plugins e/ou atualização de plugins já existentes;

5.10.9. Console unificada para administração de todas as funcionalidades;

5.10.10. A solução deverá automatizar a coleta de logs, análise e correlação de eventos;

5.10.11. A solução deve prover visibilidade da segurança da rede, contendo no mínimo os seguintes itens:

5.10.11.1. Identificando ativos e portas de serviços abertas.

5.10.11.2. Sistema de Detecção de Intrusão de rede.

5.10.11.3. Sistema de Detecção e Resposta para End Point (EDR).

5.10.11.4. Descoberta de ativos na rede

5.10.11.5. Busca de Vulnerabilidade

5.10.11.6. Monitoramento de Vulnerabilidades

5.10.11.7. Monitoramento de Dark Web

5.10.12. A soluções deve alertar através da console e através de e-mails caso o ambiente esteja sofrendo algum tipo de ataque;

5.10.13. A solução deverá oferecer relatórios pré-configurados de compliance de, no mínimo, PIC, HIPAA, NIST e ISO27001;

5.10.14. A solução deverá ser certificada em ISSO 27001 e PCI-DSS

5.10.15. A solução também deverá permitir criação de relatórios customizados;

5.10.16. A solução deverá prover gráficos interativos com indicadores de visibilidade de rede.

5.10.17. Possuir relatórios sobre os principais alarmes, principais invasores, principais hosts atacados e principais portas de destino;

5.10.18. Relatórios sobre ativos, incluindo propriedades de ativos, vulnerabilidades, eventos, alarmes e registros brutos para ativos selecionados;

5.10.19. Relatórios sobre vários regulamentos de conformidade, incluindo FISMA, HIPAA, ISO 27001, PCI 2.0, PCI 3.0, PCI DSS 3.1 e SOX. Esses relatórios exibem informações, como eventos, alarmes e ativos, e os mapeiam para os requisitos de conformidade.

5.10.20. Relatórios de logs brutos de diferentes origens, como firewalls, sistemas IDS / IPS, dispositivos de segurança de e-mail e aplicativos antivírus.

5.10.21. Relatórios sobre operações de segurança, incluindo tickets, principais alarmes e principais eventos de segurança.

5.10.22. Relatar a atividade do usuário na interface da Web.

5.10.23. Relatórios sobre tickets abertos em eventos, alarmes, métricas, vulnerabilidades e anomalias.

5.10.24. Permitir descoberta de ativos na rede de forma ativa e passiva;

5.10.25. Permitir descoberta de ativos por rede ou sub-rede;

5.10.26. Permitir agendamento de descoberta de ativos;

5.10.27. Permitir a criação de grupos para melhor controle e gestão dos ativos.

5.10.28. Capacidade de criação de tarefas específicas por grupo.

5.10.29. Permitir organização automática de ativos em grupos, forçando alguns tipos de ativos descoberto a se tornarem membros de determinados grupos;

5.10.30. A criação de grupo deverá ser baseada através de atributo, como:

5.10.30.1. Valor do ativo;

5.10.30.2. Rede;

5.10.30.3. Software em execução nos ativos;

5.10.30.4. Tipo de dispositivo;

5.10.30.5. Portas abertas ou serviços em execução nos ativos;

5.10.30.6. Capacidade de importar lista de ativos através de arquivo .CSV;

5.10.31. Deverá possuir as seguintes ações para o ativo:

5.10.31.1. Editar;

5.10.31.2. Deletar;

5.10.31.3. Executar verificação de ativos;

5.10.31.4. Executar varredura de vulnerabilidade;

5.10.31.5. Ativar o monitoramento de disponibilidade;

5.10.31.6. Desativar o monitoramento de disponibilidade;

5.10.32. Deverá possuir detalhes do ativo, como: Hostname ou IP, Sistema Operacional e Status contendo informações de Alertas, Vulnerabilidades, Eventos, dentre outros.

5.10.33. Permitir adicionar ativos das seguintes maneiras:

5.10.33.1. Manualmente;

5.10.33.2. Através de escaneamento de rede;

5.10.33.3. Através de arquivo contendo redes e/ou ativo com a extensão CSV;

5.10.34. A solução deve permitir a descoberta de vulnerabilidade com no mínimo as seguintes opções:

5.10.34.1. Escaneamento de vulnerabilidades único ativo identificado.

5.10.34.2. Escaneamento de vulnerabilidades de um grupo de ativos identificados.

5.10.34.3. Escaneamento de vulnerabilidades por endereço de rede e range de endereços de rede.

5.10.34.4. O escaneamento de vulnerabilidades deve gerar visualização em tela e opção de emissão de relatório.

5.10.35. A solução deve permitir o agendamento da tarefa de escaneamento de vulnerabilidades no mínimo seguindo as opções de intervalo por tempo: minuto, hora, dia, semana, mês e ano.

5.10.36. Deverá possuir valores definidos de limitadores e métricas;

5.10.37. Deverá possuir, no mínimo, 3 (três) perfis de varredura de vulnerabilidade;

5.10.38. A solução deverá ter as seguintes funções de varredura:

5.10.39. Execução e agendamento de varreduras de vulnerabilidade

5.10.40. Gerando e examinando relatórios

5.10.41. Atualização de assinaturas de vulnerabilidade

5.10.42. As varreduras deverão possuir os seguintes horários para agendamento:

5.10.42.1. Imediatamente

5.10.42.2. Executar uma vez

5.10.42.3. Diariamente

5.10.42.4. Dia da semana

5.10.42.5. Dia do mês

5.10.42.6. Dia específico

5.10.43. A solução deve obter conhecimento no ambiente da rede e alertar no caso de identificação de alguma ação anormal ao ambiente.

5.10.44. Possuir monitoramento de rede integrando análise comportamental de rede com monitoramento de disponibilidade de serviço, a fim de prover uma ampla visão das anomalias do sistema, serviço e rede.

5.10.45. Possuir solução multicamada com IDS para rede e host.

5.10.46. Realizar análise de protocolos de rede, assim como a captura de pacotes.

5.10.47. Permitir aos analistas, realizar uma análise completa do protocolo no tráfego da rede, permitindo a reprodução completa dos eventos, para que se possa identificar o método de exploração usado ou determinar quais dados foram infiltrados.

5.10.48. Possuir análise de Netflow, trazendo informações dos protocolos utilizados, quais hosts que estão utilizando e informações sobre a largura da banda.

5.10.49. Possibilidade de gerar alarmes para quando o fluxo estiver acima ou abaixo dos limites determinados.

5.10.50. Fornecer monitoramento contínuo de serviços executados por sistemas específicos, em uma base periódica ou sob demanda.

5.10.51. Realizar teste no dispositivo visando verificar se o serviço está sendo executado corretamente.

5.11. Painel Central de Indicadores de Segurança - ITEM 11

5.11.1. O painel central de indicadores de segurança deverá processar os eventos recebidos das demais soluções que integram o objeto licitado, realizando a triagem e construindo painéis (dashboards) de acordo com as demandas da UMTI.

5.11.2. Deverá ainda possuir os seguintes recursos e funcionalidades mínimas:

a) possuir interface web em português-brasileiro para toda operação, sendo compatível no mínimo com os navegadores Edge, Internet Explorer, Firefox, Google Chrome e Safari;

b) possibilitar autenticação de usuários através de base própria, servidor LDAP ou equivalente;

c) possuir interface responsiva, possibilitando seu acesso através de dispositivos móvel;

d) deverá estar disponível para acesso via HTTPS;

e) deverá disponibilizar no mínimo três perfis de usuário: Operador, Analista e Administrador (com estas denominações ou equivalentes);

f) a solução deverá permitir a customização de painéis em função do perfil do usuário e utilização interna (painéis públicos e privados);

5.11.3. A customização dos painéis se dará através da coleta de métricas e indicadores das diversas soluções fornecidas, incluindo as já existentes;

5.11.4. A coleta das métricas e indicadores poderá ser realizada através de API's, scripts ou desenvolvimento de código específico;

5.11.5. A solução deverá oferecer no mínimo duas métricas de cada solução que compõe o objeto licitado.

6. Solução de Web Application Firewall - ITEM 12

6.1. Deverá filtrar e analisar em tempo real todos os acessos destinados às aplicações web protegidas, bloqueando em tempo real as tentativas de acesso consideradas maliciosas (ataques).

6.2. A solução deverá ser transparente, de forma a dispensar totalmente qualquer configuração e mudança de código-fonte adicional às aplicações protegidas.

6.3. Deverá suportar no mínimo 10 aplicações web protegidas, sendo cada URL de domínio e subdomínio (dominio.com / exemplo.dominio.com) considerada uma aplicação.

6.4. Deverá estar estabelecida em nuvem, fora da rede da contratada, de modo a mitigar ataques sem onerar links de internet, rede interna e servidores.

6.5. Deverá atender minimamente os seguintes requisitos para segurança de aplicação:

6.5.1. Bloqueio por país;

6.5.2. Blacklist e Whitelist por IP;

6.5.3. Blacklist e Whitelist por URL;

6.5.4. Bloqueio por user-agent;

6.5.5. Bloqueio por referers.

6.6. Restringir acesso a páginas minimamente por IP, senha, desafio de captcha e 2FA com Google Auth.

6.7. Proteção contra ataques DDoS ilimitado;

6.8. Proteção contra ataques do tipo SQL Injection;

6.9. Proteção contra ataques do tipo injeção de PHP.

6.10. Proteção contra ataques do tipo XSS (Cross site scripting);

6.11. Proteção contra ataques do tipo brute force;

6.12. Proteção contra ataques de execução de comandos remotos.

6.13. Proteção contra ataques de inclusão de arquivos remotos e locais.

6.14. Proteção contra ataques de evasão.

6.15. Proteção contra bots maliciosos e de spam.

6.16. Proteção contra ferramentas de varreduras.

6.17. Proteção contra invasão a banco de dados.

6.18. Proteção contra anomalia no protocolo (HTTP).

6.19. Proteção contra ataques do tipo backdoor.

6.20. Proteção contra cookies maliciosos.

6.21. Whitelist para métodos HTTP.

6.22. Permitir a adição automática minimamente dos seguintes headers http: X-XSS-PROTECTION, X-FRAME-OPTIONS, X-CONTENT-TYPE-OPTIONS, STRICT-TRANSPORT-SECURITY e includeSubdomains.

6.23. Possuir modo de proteção para bloquear todos as requisições do tipo POST.

6.24. Possuir modo de filtro agressivo contra bots.

6.25. Possuir modo de bloqueio automático para acessos originados em redes de proxy anônimo e principais países que originam ataques (Russia, China e Turquia).

6.26. Possuir proteção nativa dos tipos virtual hardning e virtual patching.

6.27. Proteção contra envio de arquivos do tipo PHP e HTML.

6.28. Deverá possuir funcionalidade de CDN (contente delivery network), de modo a fazer caching de conteúdo dinâmico e estático em todos os pontos de presença de sua nuvem, observando minimamente os seguintes critérios:

6.29. Possuir recurso de limpeza de cache total e por arquivo via interface web e API.

6.30. Possuir modo de operação respeitando os cabeçalhos de caching fornecidos pela aplicação.

6.31. Possuir modo de operação sem CDN.

6.32. Possuir modo de operação com tempo de caching até 08 minutos.

6.33. Possuir modo de operação com tempo de caching até 180 minutos.,

6.34. Possuir recurso para ignorar o caching para um grupo de endereços IP.

6.35. Possuir suporte ao algoritmo de compressão Brotli.

6.36. Deverá permitir o uso de múltiplos IPs de hospedagem de aplicação protegida, possibilitando a configuração de balanceamento de carga ou hospedagem backup.

6.37. O recurso de balanceamento de carga deverá observar os seguintes requisitos:

6.38. Deverá realizar persistência de sessão baseada em hash de ip de origem.

6.39. Deverá dispor de opção para configuração de Timeout, a qual será respeitada para que o balanceador de carga considere o servidor de hospedagem disponível ou não.

6.40. Deverá dispor de opção na interface gráfica e API desativar ou reativar um servidor de hospedagem de aplicação.

6.41. Quando utilizada, a opção de endereço IP de hospedagem como backup, deverá ser acionar automaticamente o IP definido quando o tempo de timeout definido for alcançado para o IP principal.

6.42. Deverá suportar o uso de certificados SSL, observando minimamente os seguintes requisitos:

6.43. Dispor de modo de operação parcial, onde o certificado SSL opera somente entre os usuários e a camada de proteção (WAF) e o servidor de hospedagem não utiliza certificado.

6.44. Dispor de modo de operação total, onde o servidor de hospedagem também utiliza certificado SSL, fornecendo a criptografia em todo processo de comunicação.

6.45. Deverá permitir que certificados sejam incluídos para cada URL protegida;

6.46. Deverá incluir a emissão automática, e renovação, de certificados para todas as aplicações protegidas.

7. DAS LICENÇAS

7.1. As licenças deverão ser disponibilizadas através de arquivo e/ou chave de licenciamento disponibilizado pelo fabricante nomeados ao cliente final, e com os respectivos números de série.

7.2. Na ocasião da disponibilização das licenças, deverão ainda ser entregues os aplicativos instaladores (executáveis/binários) acompanhados de documentação técnica em formato digital (manuais de operação) de cada software que compõem a solução.

8. PRAZO CONTRATUAL

8.1. O Contrato terá duração de 12 (doze) meses, contados da assinatura do Contrato ou da última assinatura digital, podendo ser renovado/prorrogado por iguais e sucessivos períodos até o limite previsto no art. 57 da Lei 8666:93.

9. SERVIÇO DE SUPORTE TÉCNICO, MANUTENÇÃO E GARANTIA – ITENS 13, 14, 15, 16, 17 E 18

9.1. Os serviços de suporte técnico e garantia abrangem:

9.1.1. Manutenção preventiva, manutenção corretiva, esclarecimento de dúvidas e reparação de problemas na solução;

9.1.2. Elaboração de relatórios, estudos e diagnósticos sobre o ambiente da solução;

9.2. Os serviços de suporte técnico e garantia abrangem todas as soluções fornecidas pela contratada no âmbito dessa contratação.

9.3. Os serviços de suporte técnico e garantia de toda a solução deverão ser prestados por um período de 12 (doze) meses e deverão ser iniciados a partir da data Emissão do Termo de Aceite e Entrega da Solução.

9.4. Os serviços de suporte técnico poderão ser prestados de forma remota ou presencial no endereço da CONTRATANTE.

9.5. Os bens e produtos adquiridos devem ser licenciados de forma que o suporte e a garantia permitam as atualizações dos sistemas e ferramentas durante a vigência do contrato. Deverão estar incluídas tanto as atualizações de segurança, quanto as atualizações para novas versões dos softwares licenciados, quando disponibilizadas, independente da política de comercialização do fabricante.

9.6. Todas os sistemas ou ferramentas que fazem parte da solução deverão ser disponibilizados na versão mais recente disponibilizada pelo fabricante.

9.7. A CONTRATADA deve garantir que todas as personalizações e configurações realizadas sejam automaticamente portadas para novas versões em caso de atualização, reinstalação ou upgrade, dispensando a necessidade de migrações ostensivas e onerosas.

9.8. O serviço Suporte Técnico e Manutenção servirá para que a contratada, através de equipe própria e comprovadamente especializada na solução, execute serviços inerentes às rotinas técnicas operacionais dos softwares fornecidos.

9.9. Os serviços de Suporte Técnico, Manutenção e Garantia serão mensurados como serviço mensal, tendo sua verificação a partir da constante estabilidade e evolução da Solução no ambiente da Unidade Municipal De Tecnologia Da Informação/UMTI totalmente integrada com os diversos segmentos da rede corporativa.

9.10. A CONTRATADA deverá disponibilizar o canal de suporte técnico, através de serviço telefônico, por no mínimo, 8x5 (oito horas por dia, cinco dias por semana), através de um número local ou 0800 (zero oitocentos) a um Centro de Atendimento por Voz, com atendimento, obrigatoriamente em língua portuguesa, falada no Brasil, devendo operar, no mínimo, em dias úteis no horário comercial, das 8h (oito horas) às 18h (dezoito horas), horário de Brasília.

9.11. A CONTRATADA deverá fornecer suporte técnico on-site para prestar atendimento e resolver todos os problemas relacionados à possíveis falhas ou interrupções de funcionamento da solução proposta, sempre que solicitado pela Contratante;

9.12. A CONTRATADA deverá disponibilizar por meio da Internet uma aplicação WEB para registro dos chamados de suporte técnico através de login e senha fornecida para os usuários autorizados da Contratante.

9.13. De modo a assegurar alta disponibilidade do canal de suporte técnico para o Sistema fornecido, o registro de chamados deve estar disponível em regime de 24x7x365 (vinte e quatro horas por dia durante todos os dias do ano, inclusive sábados, domingos e feriados).

9.14. Cada pessoa cadastrada no sistema como usuário deverá receber identificação e senha que permitam acesso seguro tanto ao sistema, como ao recurso de abertura de chamadas de suporte técnico, de maneira a evitar que pessoas não autorizadas possam acionar o serviço.

9.15. A Contratante poderá efetuar um número ilimitado de chamados para suporte técnico, durante a vigência do contrato, para suprir suas necessidades com relação aos produtos de segurança.

9.16. O nível de serviço de suporte técnico deverá ser prestado remotamente, de segunda a sexta-feira, em período operacional dentro do horário comercial, das 08:00 às 17:00 horas, de forma a assegurar os níveis de disponibilidade para manter a solução de segurança ofertada em perfeitas condições de uso, ainda que o registro de eventuais chamados técnicos ocorram fora do horário comercial.

9.17. Para efeito de avaliação dos níveis de serviços (acordo de nível de serviço – ANS) prestados no suporte técnico, considerar-se-á a contagem de tempo de atendimento apenas para os chamados abertos no curso do período de atendimento, em horário comercial, de modo que os chamados abertos fora deste período serão contabilizados apenas a partir do período operacional seguinte.

9.18. Relatórios sobre a prestação dos serviços: A contratada fornecerá relatórios mensais sobre a prestação dos serviços, em papel e em arquivo eletrônico, preferencialmente em formato PDF, com informações analíticas sobre os serviços realizados, incluindo-se chamados abertos e fechados, enfatizando aqueles resolvidos no período.

9.19. Constarão dos relatórios dados de todos os chamados ocorridos no período, data e hora de abertura do chamado, data e hora de início do atendimento, data e hora de fechamento do chamado, nome da pessoa que abriu o chamado, nome da pessoa que efetuou o atendimento, descrição do problema e descrição da solução.

9.20. Também devem constar dados da reabertura de chamados, quando for o caso, que foram fechados sem serem devidamente resolvidos e que, por esse motivo necessitaram ser reabertos.

9.21. Deverá ainda apresentar relatório para cada solicitação de suporte remoto, contendo data e hora da solicitação de suporte técnico, do início e do término do atendimento, identificação do problema, providências adotadas e demais informações pertinentes.

9.22. Os atendimentos das ocorrências técnicas devem ser realizados em acordo com os critérios definidos pelos níveis de serviço da tabela abaixo, estando sujeita a CONTRATADA, no caso do descumprimento dos prazos, às sanções especificadas a seguir:

9.23. ACORDO DE NÍVEL DE SERVIÇO - ANS

9.23.1. Baixa:

9.23.1.1. Descrição do chamado: Problema técnico que gere pouco ou baixo impacto na utilização da solução;

9.23.1.2. Prazo para atendimento da ocorrência: Até 48 horas úteis;

9.23.2. Média:

9.23.2.1. Descrição do chamado: Problema técnico que impeça a utilização parcial de uma funcionalidade, não impedindo por completo seu uso;

9.23.2.2. Prazo para atendimento da ocorrência: Até 24 horas úteis;

9.23.3. Alta:

9.23.3.1. Descrição do chamado: Problema técnico que impeça completamente a utilização de uma funcionalidade;

9.23.3.2. Prazo para atendimento da ocorrência: Até 12 horas úteis;

9.23.4. Urgente:

9.23.4.1. Descrição do chamado: Problema técnico que impeça a utilização da solução em sua totalidade;

9.23.4.2. Prazo para atendimento da ocorrência: Até 6 horas úteis;

9.24. Entende-se por manutenção corretiva a série de procedimentos destinados ao restabelecimento operacional da solução com todas suas funcionalidades, compreendendo, inclusive, atualização de softwares por um substituto de igual ou maior configuração, ajustes, reparos, correções necessárias e todas as configurações solicitadas pela Contratante.

9.25. Os serviços deverão ser realizados por meio de técnicos especializados, devidamente credenciados e certificados para prestar os serviços de garantia e assistência técnica on-site, de forma rápida, eficaz e eficiente, sem quaisquer despesas adicionais para a Contratante, inclusive quanto às ferramentas, equipamentos e demais instrumentos necessários à sua realização.

10. SERVIÇO DE OPERAÇÃO ASSISTIDA – ITEM 21

10.1. O serviço de operação assistida servirá para que a contratada, através de equipe própria e comprovadamente especializada na solução, execute serviços inerentes às rotinas técnicas operacionais dos softwares fornecidos.

10.2. A operação assistida deverá ser demandada através de ordem de serviço.

10.3. Quando demandado, o horário de execução do serviço de operação assistida será baseado no regime 24x7, devendo a contratada estar disponível 24h por dia.

10.4. O serviço de operação assistida poderá ser executado remotamente ou, quando solicitado, presencialmente.

10.5. As seguintes atividades técnicas operacionais compõem o serviço de operação assistida:

10.5.1. Correlação básica de logs;

10.5.2. Resolução de problemas de comunicação com os agentes;

10.5.3. Backup de configurações e demais parâmetros;

10.5.4. Atualização e correções de software;

10.5.5. Análise, validação e aprovação de políticas, quando necessário;

10.5.6. Configuração de novos agentes quando necessário;

10.5.7. Criação, alteração e configuração de novas políticas;

10.5.8. Refinamentos e melhorias no ambiente;

10.5.9. Confecção de relatórios mensais (saúde e principais eventos);

10.5.10. Monitoramento do ambiente baseados em detecção e notificação de comportamentos suspeitos;

10.5.11. Apoio aos para identificação de causas-raiz de incidentes.

10.5.12. Os serviços deverão compreender eventuais integrações necessárias ao correto funcionamento das soluções.

11. SERVIÇOS DE PROJETO E IMPLEMENTAÇÃO – ITEM 19

11.1. Para os serviços de implantação, projeto e configuração deverá ser apresentado o projeto de implementação que será a referência para a execução dos serviços de ativação das licenças;

11.2. O projeto de implementação conterá pelo menos os seguintes detalhamentos:

11.2.1. Objetivo;

11.2.2. Recomendações, riscos, premissas e restrições;

11.2.3. Matriz de Relacionamentos e Responsabilidades;

11.2.4. Organograma e funções dos envolvidos no projeto;

11.2.5. Topologias física e lógica;

11.2.6. Plano de endereçamento IPv4, VLANs e Roteamento;

11.2.7. Padrões: nomes (hostnames), DNS, SNMP e NTP;

11.2.8. Plataforma e licenciamento do ambiente virtual;

11.3. Fases do projeto:

11.3.1. INICIAÇÃO: planejamento do projeto, escopo de trabalho, cronograma e entregáveis. O prazo para entrega do planejamento de implementação por parte da CONTRATADA será de até de 30 (trinta dias) dias corridos da assinatura do contrato e a CONTRATANTE terá até 5 (cinco) dias corridos para formalizar o aceite ou observações do projeto;

11.3.2. PLANEJAMENTO: consiste na elaboração dos processos utilizados na implementação do projeto e revisão de todas as questões técnicas necessárias, incluindo: espaço físico, licenças, energia, cabeamento de dados, padrões (nomes, segurança física, contatos e funções, parâmetros lógicos (endereços IP, resolução de nomes, referências de tempo, gerenciamento etc.);

11.3.3. INSTALAÇÃO: instalação física, energização e cabeamento de dados, de equipamentos conforme determinado no projeto executivo; verificação da versão de sistemas e licenças, instalação lógica e licenciamento; acessos aos ambientes fornecidos em nuvem, configuração básica para acesso via IP;

11.3.4. CONFIGURAÇÃO: executar configurações das facilidades (customização). Essas atividades compreendem: configuração dos serviços pertinentes de cada item que compõe o edital, testes específicos de cada item, aceites específicos de cada item, configuração da gestão, dashboards e indicadores e aceite da plataforma;

11.3.5. DOCUMENTAÇÃO: geração do relatório técnico descrevendo todas as configurações realizadas;

11.3.6. ENCERRAMENTO: a fim de comprovar a entrega do serviço de implementação deverão ser entregues a documentação com evidências do licenciamento das soluções que compõem a plataforma e todos os seus componentes, binários, executáveis, aplicativos para instalação ou link para download das soluções que compõem a plataforma e relatório com evidências que comprovem a entrega dos serviços;

11.4. Condições gerais de prestação dos serviços:

11.4.1. A CONTRATADA deverá fornecer mão de obra especializada e própria para realizar as atividades do contrato, sendo que a CONTRATADA deverá apresentar relação contendo os nomes dos empregados que trabalharão na execução do contrato e copias de registros dos mesmos junto a empresa, devidamente anotado na carteira de trabalho e previdência social – CTPS:

11.4.2. Os serviços de implementação preferencialmente serão realizados em horário comercial, das 08h00 às 17h00, de segunda a sexta-feira, excetuando-se feriados nacionais, estaduais e municipais da cidade de onde serão prestados, exceto horários que poderão ser estabelecidos fora de horário comercial e nos finais de semana, a critério da CONTRATANTE;

11.4.3. O prazo para implementação da solução por parte da CONTRATADA, será de 90 (noventa) dias corridos a partir da assinatura do contrato;

11.4.4. Embora conste previsto que os trabalhos terão o acompanhamento por parte da equipe técnica da CONTRATANTE, cabe intensificar o entendimento que a COTRATADA terá exclusiva responsabilidade quando à entrega dos serviços destacados, uma vez que estejam em plenas condições de operação munidos de todos os requisitos fornecidos pela CONTRATANTE e de acordo com os prazos estabelecidos;

12. DAS OBRIGAÇÕES DA CONTRATADA

12.1. A Contratada deverá oferecer garantia e suporte para a solução e suas funcionalidades contratadas pelo período da vigência do contrato. A CONTRATADA deverá prestar Serviços de Manutenção "On Site", para todos os componentes do objeto deste edital, incluindo configuração técnica das soluções;

12.2. Disponibilizar profissionais qualificados para a solução fornecida;

12.3. Instalar, configurar e acompanhar os testes de funcionamento antes da entrada de produção dos equipamentos;

12.4. Orientar tecnicamente os responsáveis pela operação dos equipamentos, fornecendo os esclarecimentos necessários ao seu perfeito funcionamento;

12.5. Disponibilizar número de telefone (local ou DDG) para suporte telefônico e abertura de chamados técnicos, ou deverá disponibilizar uma aplicação WEB para registro dos chamados de suporte técnico através de login e senha fornecida para os usuários autorizados da CONTRATANTE, de modo a assegurar alta disponibilidade do canal de suporte técnico para o Sistema fornecido.

12.6. O registro de chamados deve estar disponível em regime de 24x7x365 (vinte e quatro horas por dia durante todos os dias do ano, inclusive sábados, domingos e feriados).

12.7. Cada pessoa cadastrada no sistema como usuário deverá receber identificação e senha que permitam acesso seguro tanto ao sistema, como ao recurso de abertura de chamadas de suporte técnico, de maneira a evitar que pessoas não autorizadas possam acionar o serviço;

12.8. Ao final da abertura de cada atendimento de suporte, a CONTRATADA deverá emitir um ticket do chamado técnico contendo, no mínimo:

12.8.1. Número do chamado;

12.8.2. Data e hora de abertura do chamado;

12.8.3. Previsão de conclusão do atendimento;

12.8.4. Severidade do erro;

12.8.5. Descrição da solicitação.

12.9. A CONTRATADA deverá disponibilizar relatórios de chamados por período, contendo, no mínimo, as seguintes informações:

12.9.1. Número do chamado;

12.9.2. Data e hora de abertura do chamado;

12.9.3. Data e hora do início do tratamento do chamado;

12.9.4. Data e hora de resolução do chamado;

12.9.5. Prazo Total de Início do Tratamento do Chamado (ITC);

12.9.6. Prazo Total de Resolução do Chamado (PRC)

12.9.7. Início do Tratamento do Chamado (ITC) cumprido (Sim/Não);

12.9.8. Prazo para Resolução do Chamado (PRC) cumprido (Sim/Não);

12.9.9. Contato do técnico atendente;

12.9.10. Responsável pelo registro do chamado;

12.9.11. Severidade do chamado;

12.9.12. Descrição da solicitação;

12.9.13. Solução aplicada;

12.10. Depois de concluído o chamado, a CONTRATADA comunicará o fato à equipe técnica da CONTRATANTE e solicitará autorização para o fechamento deste. Caso a CONTRATANTE não confirme a solução definitiva do problema, o chamado permanecerá aberto até que seja efetivamente solucionado pela CONTRATADA. Nesse caso, a CONTRATANTE fornecerá as pendências relativas ao chamado aberto.

12.11. A CONTRATANTE poderá registrar um número ilimitado de chamados de suporte durante a vigência do Contrato.

12.12. Os atendimentos das ocorrências técnicas devem ser realizados em acordo com os critérios definidos pelos níveis de serviço descrito no item SERVIÇO DE SUPORTE TÉCNICO, MANUTENÇÃO E GARANTIA, estando sujeita a CONTRATADA, no caso do descumprimento dos prazos, às sanções especificadas neste documento.

12.13. Toda infraestrutura necessária para o pleno funcionamento da Plataforma única de Gestão de Dados, tais como: servidores, sistemas operacionais, banco de dados, licenças, entre outros hardwares e softwares necessários, deverá ser disponibilizada no datacenter da CONTRATANTE pela CONTRATADA;

12.14. A Contratada deverá acompanhar com pessoal in loco o primeiro dia útil de operação do ambiente em produção.

12.15. Prover todo o suporte necessário para a implantação da solução, incluindo interações com os fabricantes das soluções de SGBD, NAS (system file) e principalmente com as equipes de desenvolvimento da CONTRATANTE para integração da solução contratada nas aplicações existentes da CONTRATANTE.

13. OBRIGAÇÕES DA CONTRATANTE

13.1. Nomear gestor e fiscal do contrato para acompanhar e fiscalizar a execução do contrato;

13.2. Encaminhar formalmente à Contratada a demanda de acordo com os critérios técnicos estabelecidos no Termo de Referência;

13.3. Comunicar formalmente à Contratadas quaisquer ocorrências relacionadas a execução do contrato;

13.4. Disponibilizar a infraestrutura de sua responsabilidade para que as soluções contratadas sejam instaladas e configuradas;

14. DA ACEITABILIDADE DA PROPOSTA

14.1. A proposta da licitante deverá conter uma Proposta Técnica contemplando, no mínimo a especificação clara e completa dos bens e serviços, obedecida a mesma ordem constante deste Termo de Referência, sem conter alternativas de preços, ou de qualquer outra condição que induza o julgamento a ter mais de um resultado.

14.2. Não serão aceitas propostas contendo cópia das exigências deste Termo de Referência no lugar da especificação clara e inequívoca dos serviços a serem executados.

14.3. A licitante vencedora deverá apresentar Proposta Comercial, contendo a planilha de preços, discriminando os valores total e unitário dos bens e serviços contratados.

14.4. A proposta da licitante deverá estar integralmente preenchida, discriminando os valores unitários e totais dos bens e serviços objeto deste Termo de Referência, em conformidade com o modelo constante do anexo específico neste Termo de Referência.

14.5. A proposta deverá conter declaração específica da licitante de que se encontra apta a fornecer todos as Soluções e serviços pertinentes ao ofertado e às regras de negócio envolvidas.

14.6. Sob pena de desclassificação de sua proposta, a licitante deverá apresentar ainda, juntamente com sua proposta técnica e comercial, catálogo, folder, prospectos, fotos ou folhetos ilustrativos, ou manual técnico elaborado pelo fabricante, ou documento extraído de consulta realizada pela internet, devendo, nesse caso, ser indicado o endereço eletrônico, que possibilite uma análise objetiva sobre as características do objeto ofertado.

14.7. Além da documentação acima indicada, para aceitabilidade da proposta será obrigatória a realização de Teste de Bancada dos requisitos técnicos objetivos indicados no Roteiro de Teste de Bancada – Anexo xx do presente termo de referência. O Teste de bancada será exigido da empresa provisoriamente classificada em primeiro lugar, após a etapa de lances, conforme procedimento indicado no ITEM 18 deste Termo de Referência (DO TESTE DE BANCADA).

15. CONDIÇÕES DE FATURAMENTO

15.1. Os serviços da futura contratação serão pagos por meio dos seguintes critérios:

a) Para as Licenças Perpétuas, deverão ser **faturados integralmente em parcela única (licença perpétua)** a partir da conclusão do fornecimento e instalação da solução em ambiente dessa administração.

b) Para as Licenças de Subscrição Mensal, deverão ser **faturados mensalmente em parcela única (licença perpétua)** a partir da ativação das licenças no ambiente computacional dessa administração.

b.1) Deverá ser extraído da console de gerenciamento o relatório que demonstre o pleno funcionamento do equipamento e os softwares vinculados para a ação de criptografia nos cenários listados.

b.2) De posse do relatório será deverá ser emitido termo de ateste a instalação da solução e o encaminhamento da Nota Fiscal Eletrônica de Serviços deverá ser realizado através de Solicitação de Pagamento, a partir do 1º (primeiro) dia subsequente à emissão do termo acima.

c) Os serviços de Suporte Técnico, Manutenção e Garantia deverão ser atestados através de relatório técnico emitido pela contratada e o encaminhamento da Nota Fiscal Eletrônica de Serviços deverá ser realizado através de Solicitação de Pagamento, a partir do 1º (primeiro) dia do mês subsequente à prestação do serviço mensal.

d) O Serviço de Operação Assistida será **mensurado como um serviço mensal** e deverá ser atestado através de relatório técnico emitido pela contratada e o encaminhamento da Nota Fiscal Eletrônica de Serviços deverá ser realizado através de Solicitação de Pagamento, a partir do 1º (primeiro) dia do mês subsequente à prestação do serviço;

e) O serviço de Instalação e Configuração é considerado **atividade de execução única** e faturado a partir da emissão do Termo de Aceite de Conclusão da Instalação e Configuração e o encaminhamento da Nota Fiscal Eletrônica de Serviços deverá ser realizado através de Solicitação de Pagamento, a partir do 1º (primeiro) dia subsequente à emissão do termo acima e autorização do Gestor do Contrato;

f) O valor relativo ao Treinamento será faturado a partir da emissão do Termo de Aceite de Conclusão de Treinamento e o encaminhamento da Nota Fiscal Eletrônica de Serviços deverá ser realizado através de Solicitação de Pagamento, a partir do 1º (primeiro) dia subsequente à emissão do termo acima e autorização do Gestor do Contrato.

16. CONDIÇÕES DE PAGAMENTO

16.1. A Nota Fiscal Eletrônica de Serviços deverá ser emitida e encaminhada à CONTRATANTE, através do setor de Expediente, por meio do endereço eletrônico bruno.crispim@joaopessoa.pb.gov.br

16.2. Após o recebimento da Nota Fiscal Eletrônica de Serviços, a CONTRATANTE disporá de até 05 (cinco) dias úteis para emissão do Termo de Aceite, aprovando os serviços prestados.

16.3. O pagamento será realizado por intermédio de crédito em conta corrente ou por outra modalidade que possa vir a ser determinada pela Unidade Municipal De Tecnologia Da Informação/ UMTI em 30 (trinta) dias corridos a contar da data de emissão do Termo de Aceite;

16.4. Caso a Nota Fiscal Eletrônica de Serviços contenha divergências com relação ao estabelecido no Instrumento Contratual, a CONTRATANTE ficará obrigada a comunicar a empresa CONTRATADA, formalmente, o motivo da não aprovação no prazo de 05 (cinco) dias úteis. A devolução da Nota Fiscal Eletrônica de Serviços, devidamente, regularizada pela CONTRATADA, deverá ser efetuada em até 05 (cinco) dias úteis da data de comunicação formal realizada pela CONTRATANTE;

16.5. Em caso de atraso de pagamento dos valores devidos à CONTRATADA, mediante requerimento formalizado por esta, incidirão juros moratórios calculados utilizando-se o índice oficial de remuneração básica da caderneta de poupança e de juros simples no mesmo percentual de juros incidentes sobre a caderneta de poupança, para fins de compensação da mora (TR + 0,5% “pro-rata tempore”), observando-se para tanto, o período correspondente à data prevista para o pagamento e aquela data em que o pagamento efetivamente ocorreu.

17. QUALIFICAÇÃO TÉCNICA

17.1. A LICITANTE deverá apresentar, em seu nome, atestado (s) de capacidade técnica, emitido por pessoa jurídica de direito público ou privado, comprovando ter fornecido solução de natureza semelhante e compatível ao objeto licitado

17.2. Entende-se por semelhante ou compatível ao objeto licitado a apresentação de atestado(s) fornecido(s) por pessoas jurídicas de direito público ou privado, contemplando, no mínimo, o fornecimento de Plataforma integrada de Segurança da Informação, compreendendo no mínimo as seguintes parcelas de maior relevância abaixo indicadas:

a) Fornecimento/licenciamento de solução de Gerenciamento de chaves criptográficas e criptografia para Servidores De Arquivos e Aplicações Web;

b) Fornecimento/licenciamento de solução de Identificação e Classificação de dados;

c) Fornecimento/licenciamento de solução de Prevenção de vazamento de dados;
d) Fornecimento/licenciamento de solução de Gestão de Identidade e Acesso;
e) Prestação de serviços de operação assistida para solução de segurança da informação.

17.3. O (s) atestado(s) deverá(ão) conter obrigatoriamente nome das empresas declarantes, a identificação do nome e a assinatura do responsável, bem como o número de telefone para contato;

17.4. Poderão ser exigidos documentos comprobatórios do efetivo fornecimento, em caráter de diligência.

18. DO TESTE DE BANCADA

18.1. A classificação da empresa provisoriamente classificada em primeiro lugar, após a etapa de lances, ficará condicionada, ainda, à comprovação das especificações gerais e funcionalidades deste Termo de Referência. Para tanto, deverá executar um Teste de Bancada.

18.2. Caso a licitante não atenda as exigências do teste de bancada ou qualquer dos documentos de habilitação, o pregoeiro examinará a proposta subsequente e assim sucessivamente, na ordem de classificação, até a seleção da proposta que melhor atenda este Edital.

18.3. A licitante melhor classificada deverá prestar apoio e esclarecimentos necessários durante a apresentação e execução do teste de bancada, dando subsídios para que a CONTRATANTE possa classificar a solução proposta.

18.4. O teste de bancada será realizado no endereço da Unidade Municipal De Tecnologia Da Informação/ UMTI em horário comercial, de segunda a sexta-feira, das 8h às 12h e das 14h às 17h.

18.5. Após a análise da documentação, respeitada a ordem de classificação do certame, o pregoeiro comunicará, via chat, a licitante que atenda ao edital quanto à documentação habilitatória, para que proceda ao agendamento do teste de bancada junto à área técnica através do e-mail bruno.crispim@joaopessoa.pb.gov.br, conforme disposto a seguir:

18.6. A empresa convocada via chat na sessão do Pregão, terá 2 dias úteis para agendamento através do e-mail bruno.crispim@joaopessoa.pb.gov.br, sob pena de desclassificação pelo não cumprimento deste prazo;

18.7. O prazo para início do teste de bancada não será superior a 5 dias úteis após o agendamento;

18.8. Caso a empresa convocada não atenda os prazos, será considerada desclassificada;

18.9. As demais empresas interessadas em assistir ao teste de bancada, terão dois dias úteis para agendamento através do e-mail bruno.crispim@joaopessoa.pb.gov.br, a partir da convocação do pregoeiro à empresa que realizará o teste de bancada, indicando representante legal da licitante, devidamente identificado por meio de vínculo contratual ou procuração, como "Técnico de Acompanhamento da Licitante Participante". O não cumprimento deste prazo, ensejará na queda do direito de assistir à realização do teste de bancada.

18.10. Não será permitida a substituição de qualquer Técnico de Acompanhamento da licitante participante sem a autorização prévia da Unidade Municipal De Tecnologia Da Informação/ UMTI;

18.11. Não será permitida a comunicação direta entre qualquer Técnico de Acompanhamento da licitante participante e a Equipe Técnica da licitante convocada. Qualquer comunicação ou questionamento deve ser dirigido unicamente à Equipe Técnica da Unidade Municipal De Tecnologia Da Informação/ UMTI;

18.12. A não observância dessa regra de comunicação poderá causar o descredenciamento da Equipe Técnica da licitante convocada ou de qualquer técnico de acompanhamento da licitante participante;

18.13. O teste de bancada deverá atestar as funcionalidades constantes no Roteiro de Teste de bancada conforme anexo IV;

18.14. A licitante convocada terá um prazo de até 3 (três) dias úteis para a completa execução dos testes;

18.15. A licitante convocada deverá prover, integralmente às suas custas, toda a infraestrutura necessária para a completa execução do teste de bancada;

18.16. Fica a critério da licitante optar por demonstrar os testes de funcionalidade, de acordo com o roteiro de teste de bancada, em ambiente local ou virtual (nuvem). Contudo, a execução dos testes deverá ocorrer nas dependências da Unidade Municipal De Tecnologia Da Informação/ UMTI.

18.17. A solução ofertada deverá então ser atualizada para a versão mais atual do software;

18.18. A conformidade com as especificações técnicas e comprovação da execução da solução, de acordo com o roteiro de teste de bancada, ensejará a CLASSIFICAÇÃO da licitante no certame. Do contrário, a reprovação da solução ofertada implicará na desclassificação da licitante;

19. TREINAMENTO – ITEM 20

19.1. Os serviços de treinamento aos funcionários indicados pela CONTRATANTE, deverá considerar seguintes características mínimas:

19.1.1. Uma turma para até 10 (dez) participantes com carga horária de 40 (quarenta) horas;

19.1.2. A data de aplicação do treinamento será fixada de comum acordo com a CONTRATANTE;

19.1.3. O conteúdo do treinamento deverá abranger a apresentação da arquitetura da plataforma, a visão geral de funcionamento de cada item da plataforma, os principais indicadores, alertas e relatórios, respostas a incidentes, acordo de nível de serviço e escalonamento de chamados e a configuração dos painéis de indicadores;

19.1.4. Todo o material didático deve ser repassado de forma impressa e em meio eletrônico para os alunos;

19.1.5. O(s) instrutor(es) deverá(ão) possuir experiência nas tecnologias e didática, além de possuir certificação na área de segurança;

19.1.6. O treinamento deverá ocorrer nas dependências da CONTRATANTE, ou local por ela indicado, ficando a mesma responsável por montar o ambiente adequado para realização dele, isto é, todo o espaço necessário assim como toda infraestrutura computacional e de rede necessária;

19.1.7. Caberá à CONTRATADA, se necessário, instalar a plataforma e demais softwares que compõem a solução ou possibilitar o acesso ao ambiente de treinamento;

19.1.8. Todas as despesas relativas à execução do treinamento serão de exclusiva responsabilidade da CONTRATADA, incluindo os gastos com instrutores, estadia, transporte e alimentação, assim como o material didático.

19.1.9. Para fins de comprovação da execução dos serviços de treinamento, a CONTRATADA deverá entregar a lista de presença dos participantes do treinamento e o certificado de execução do treinamento para cada participante ao término do treinamento.

20. VISTORIA

20.1. Para o correto dimensionamento e elaboração de sua proposta, a licitante poderá visitar o local onde serão executados os serviços, para se inteirar de todos os aspectos referentes à sua execução;

20.2. A visita deverá ser realizada por intermédio de representante legal do licitante que assinará a Declaração de Vistoria, conforme modelo constante no ANEXO II. Esta visita, necessariamente, será acompanhada por técnico do órgão licitante, igualmente habilitado;

20.3. O agendamento deverá ser realizado através do e-mail: bruno.crispim@joaopessoa.pb.gov.br ou pelo telefone (83) 3218-9138.

20.4. A vistoria poderá ser realizada em até 2 (dois) dias antes do início da Sessão Pública;

20.5. Todos os custos associados com a visita serão de inteira responsabilidade da licitante;

20.6. O licitante que optar pela não realização da visita técnica deverá entregar por ocasião do certame, Declaração em papel timbrado da empresa, assinado por representante legal, afirmando que tinha ciência da possibilidade de fazê-la, mas que, ciente dos riscos e consequências envolvidos, optou por formular a proposta sem realizar a visita técnica que lhe havia sido facultada (ANEXO III).

21. PRAZO DE ENTREGA

21.1. O prazo máximo de entrega de todos as soluções que compõem a solução serão de 60 (sessenta) dias corridos, contados a partir da data de abertura de ordem de serviço.

21.2. Prazo máximo para Instalação e configuração (implementação) da solução será de 90 (noventa) dias corridos contados a partir da entrega dos equipamentos, devendo obrigatoriamente ser realizada em finais de semana ou feriados, conforme agendamento da contratante.

21.3. Toda a solução deverá ser entregue e instalada no Município de João Pessoa;

21.4. Toda a solução deverá ser instalada nos sites da Unidade Municipal De Tecnologia Da Informação/ UMTI, sito à R. Diógenes Chianca, 1777 - Água Fria, cidade de João Pessoa-PB.

22. CRONOGRAMA DE IMPLANTAÇÃO E CRONOGRAMA FÍSICO FINANCEIRO

22.1. Cabe observar que a natureza de diversas soluções a serem implementadas é realizar controles e gerir a informação, sendo esse um processo contínuo e dinâmico. Portanto, a implementação é realizada em primeiro lugar disponibilizado as ferramentas com as facilidades contratadas. Após a implementação se inicia a fase de Operação onde as regras, relatórios, indicadores e políticas são definidas pela Unidade Municipal De Tecnologia Da Informação/ UMTI e implementada pela CONTRATADA. O cronograma abaixo sugerido trata apenas da disponibilização das soluções de forma que a Unidade Municipal De Tecnologia Da Informação/ UMTI, através da CONTRATADA, possa iniciar a aplicação de regras, controles e políticas:

MÊS	**1**				**2**			
SEMANAS	**1**	**2**	**3**	**4**	**5**	**6**	**7**	**8**
1. PLANEJAMENTO E PROJETO								
1.1 Levantamento preliminar de informações								
1.2 Aprovação/Ajustes do Projeto Executivo								
2. IMPLEMENTAÇÃO DAS SOLUÇÕES TECNOLÓGICAS								
2.1 Console de Gerenciamento de Chaves Criptográficas								
2.2 Criptografia para Sistemas de Arquivos de Servidores								
2.3 Criptografia de Registros em banco de Dados via Aplicações Web								
2.4 Criptografia para Compartilhamento Seguro de Base de Dados								
2.6 Agente de Gestão de Chave local								
2.7 Módulo de Identificação e Classificação de dados.								
2.8 Solução de gestão de identidade e acesso								
2.7 Solução de Prevenção de vazamento de dados.								
2.8 Solução de Gestão de Credenciais de alto privilégio								
2.9 Solução de Gestão e Correlação de eventos de segurança								
2.10 Solução de Painel Central de Gerenciamento de Indicadores de Segurança								
2.11 Solução de Web Application Firewall								
3. Treinamento – Datas a serem definidas posteriormente em função da disponibilidade dos profissionais.								
4. Início da Operação								

Observações:

1. As licenças, para efeito de utilização, serão contabilizadas a partir de sua data de ativação.

CRONOGRAMA FÍSICO-FINANCEIRO

ITEM	DESCRIÇÃO DA SOLUÇÃO	MÊS											
		1	2	3	4	5	6	7	8	9	10	11	12
1	Console de Gerenciamento de Chaves Criptográficas												
2	Criptografia para Sistemas de Arquivos de Servidores												
3	Criptografia de Registros em banco de Dados via Aplicações Web												
4	Criptografia para Compartilhamento Seguro de Base de Dados												
5	Agentes para Gestão de Chave de Terceiro												
6	Módulo de Identificação e Classificação de dados.												
7	Solução de gestão de identidade e acesso												
8	Solução de Prevenção de vazamento de dados.												
9	Solução de gestão de credenciais de alto privilégio												
10	Solução de Gestão e Correlação de eventos de segurança												
11	Solução de Painel Central de Gerenciamento de Indicadores de Segurança												
12	Solução de Web Application Firewall												
13	Manutenção e Garantia de Console de Gerenciamento de Chaves Criptográficas												
14	Manutenção e Garantia para Criptografia para Sistema de Arquivos de Servidores												
15	Manutenção e Garantia para Criptografia de Registros em Bancos de Dados via Aplicações Web												
16	Manutenção e garantia para Criptografia de Compartilhamento seguro da base de dados												
17	Manutenção e Garantia de Agente de Gestão de Chave de Terceiro.												
18	Manutenção e Garantia para Solução de gestão de credenciais de alto privilégio												
19	Serviços de projeto e implementação												
20	Serviços de operação												
21	Serviços de treinamento												

23. CONFIDENCIALIDADE

23.1. A CONTRATADA deverá zelar pelo sigilo de quaisquer informações referentes à estrutura, sistemas, usuários, contribuintes, topologia, e ao modo de funcionamento e tratamento das informações da CONTRATANTE, durante e após fim do contrato, salvo se houver autorização expressa da Contratante para divulgação;

23.2. Não haverá nenhum tipo de facilidade de acesso remoto, tão menos envio de forma automática ou controlada de informações (backdoor) originadas de software/hardware contratado ou adquirido sem o conhecimento e formal autorização da Contratante. A não observância deste fato poderá ser considerada espionagem e será motivo de processo civil e criminal conforme legislação vigente.

24. ACEITE

24.1. Após a instalação e configuração da solução, a equipe técnica da Unidade Municipal De Tecnologia Da Informação/ UMTI emitirá o "Termo de Aceite de Entrega e Instalação" das licenças perpétuas em até 5 (cinco) dias úteis após a formalização pela CONTRATADA da finalização do processo da instalação/configuração (operação) da solução e confirmação que todos os quesitos estão sendo cumpridos conforme o Edital.

24.2. Entende-se pela instalação e configuração, tanto a parte física da solução, configuração lógica de todos os produtos/serviços e testes de todas as regras e procedimentos necessários a operação do serviço.

ANEXO II

MODELO REFERENTE A VISITA TÉCNICA

CERTIFICADO DE REALIZAÇÃO DE VISITA TÉCNICA
(emitido pela Unidade Compradora)

REF.: PE n.º _____/2022

ATESTO que o representante legal do licitante _____, interessado em participar do Pregão Eletrônico nº ___/___, Processo n° ___/___, realizou nesta data visita técnica nas instalações do _____, recebendo assim todas as informações e subsídios necessários para a elaboração da sua proposta.
O licitante está ciente desde já que, em conformidade com o estabelecido no Edital, não poderá pleitear em nenhuma hipótese modificações nos preços, prazos ou condições ajustadas, tampouco alegar quaisquer prejuízos ou reivindicar quaisquer benefícios sob a invocação de insuficiência de dados ou informações sobre os locais em que serão executados os serviços.

(local e data)

_____	_____
(nome completo, assinatura e qualificação do representante da licitante)	(nome completo, assinatura e cargo do servidor responsável por acompanhar a visita)

ANEXO III

DECLARAÇÃO DE RENÚNCIA A VISITA TÉCNICA

(Papel Timbrado do Licitante)

REF.: PE n.º _____/2022

Eu, _____, portador do RG nº _____ e do CPF nº_____, na condição de representante legal de _____ (*nome empresarial*), interessado em participar do Pregão Eletrônico nº ___/___, Processo n° ___/___, **DECLARO** que o licitante não realizou a visita técnica prevista no Edital e que, mesmo ciente da possibilidade de fazê-la e dos riscos e consequências envolvidos, optou por formular a proposta sem realizar a visita técnica que lhe havia sido facultada.

O licitante está ciente desde já que, em conformidade com o estabelecido no Edital, não poderá pleitear em nenhuma hipótese modificações nos preços, prazos ou condições ajustadas, tampouco alegar quaisquer prejuízos ou reivindicar quaisquer benefícios sob a invocação de insuficiência de dados ou informações sobre os locais em que serão executados os serviços.

(Local e data)

_____

(nome completo, assinatura e qualificação do proposto da licitante)

ANEXO IV - MODELO DE PROPOSTA DE PREÇOS
(em papel timbrado da empresa)

À
xxxxxxx
Área demandante
Endereço
Referência: Pregão Eletrônico PE nº ___/2022.

Proposta que faz a empresa _____, inscrita no CNPJ nº_____ e inscrição estadual nº _____, estabelecida no(a)_____, para eventual fornecimento de (INDICAR OBJETO), para atender às necessidades da xxxxxxxx, de acordo com as especificações e condições constantes do Pregão em referência, bem como do respectivo Edital e seus Anexos.

ITEM	DESCRIÇÃO	MÉTRICA	QUANT.	Valor Unitário (R$)	Valor Mensal (R$)	Valor Total (R$)
1	Console de Gerenciamento de Chaves Criptográficas	Licença Perpétua / Aquisição	2	R$		R$
2	Criptografia para Sistemas de Arquivos de Servidores	Licença Perpétua / Aquisição	2	R$		R$
3	Criptografia de Registros em Bancos de Dados via Aplicações Web	Licença Perpétua / Aquisição	5	R$		R$
4	Criptografia para Compartilhamento Seguro de Base de Dados	Licença Perpétua / Aquisição	1	R$		R$
5	Agente de Gestão de Chave de Terceiro	Licença Perpétua / Aquisição	2	R$		R$
6	Módulo de Identificação e Classificação de dados.	Licença Subscrição (Mensalidade)	12		R$	R$
7	Solução de gestão de identidade e acesso.	Licença Subscrição (Mensalidade)	12		R$	R$
8	Solução de Prevenção de vazamento de dados.	Licença Subscrição (Mensalidade)	12		R$	R$
9	Solução de gestão de credenciais de alto privilégio	Licença Perpétua / Aquisição	1	R$		R$
10	Solução de Gestão e Correlação de eventos de segurança	Licença Subscrição (Mensalidade)	12		R$	R$
11	Painel Central de Gerenciamento de Indicadores de Segurança	Licença Subscrição (Mensalidade)	12		R$	R$

12	Solução de Web Application Firewall	Licença Subscrição (Mensalidade)	12		R$	R$
13	Manutenção e Garantia de Console de Gerenciamento de Chaves Criptográficas	Serviço mensal	12		R$	R$
14	Manutenção e Garantia para Criptografia para Sistema de Arquivos de Servidores	Serviço mensal	12		R$	R$
15	Manutenção e Garantia para Criptografia de Registros em Bancos de Dados via Aplicações Web	Serviço mensal	12		R$	R$
16	Manutenção e Garantia para Criptografia de Compartilhamento Seguro de Base de Dados	Serviço mensal	12		R$	R$
17	Manutenção e Garantia de Agentes de Gestão de Chave de Terceiro	Serviço mensal	12		R$	R$
18	Manutenção e Garantia para Solução de gestão de credenciais de alto privilégio	Serviço mensal	12		R$	R$
19	Serviços de projeto e implementação	Serviço	1	R$		R$
20	Serviço de Treinamento	Serviço	1	R$		R$
21	Serviço de Operação Assistida	Serviço mensal	11		R$	R$
VALOR TOTAL GLOBAL						

Dados da Proposta	
Valor Total: R$ (VALOR POR EXTENSO).	
Validade da Proposta	60 (sessenta) dias, a contar da data de sua apresentação
Informamos, por oportuno, que nos preços apresentados acima já estão computados todos os custos necessários decorrentes da prestação dos serviços, bem como já incluídos todos os impostos, encargos trabalhistas, previdenciários, fiscais, comerciais, taxas, seguros, deslocamentos de pessoal e quaisquer outros que incidam direta ou indiretamente	
Dados da empresa	
Razão Social	
CNPJ (MF) nº	
Inscrição Estadual nº	
Endereço:	
Telefone	
Fax	
e-mail	
Cidade	
Estado	
CEP	
Representante(s) legal(is) com poderes para assinar o contrato	
Nome	
Cargo	
CPF	

RG	
Dados Bancários	
Banco	
Agência	
Conta Corrente	
Dados para Contato	
Nome	
Telefone/Ramal	

Declaramos, para todos os fins e efeitos legais, aceitar, irrestritamente, todas as condições e exigências estabelecidas no Edital da licitação em referência e do Contrato a ser celebrado, cuja minuta constitui o Anexo "__" do Edital.

Local e data

_____

Representante Legal (com carimbo da empresa)

Cargo: CPF:

ANEXO V
Roteiro de teste de bancada

Para cada item abaixo indicado, será realizada a análise de conformidade, no formato objetivo: "Atende ao requisito ou "não atende ao requisito"

Caberá ao corpo técnico desta administração avaliar e garantir a plena execução de todas as atividades relativas à avaliação de conformidade/prova de conceito, e ainda:

- Avaliar cada funcionalidade demonstrada, preenchendo questionário específico de atendimento/não atendimento, pontuando as observações necessárias;
- Emitir o "Relatório de conclusão da avaliação técnica";
- Emitir o Termo de aceite definitivo ou de recusa da solução, a fim de que se possibilite a continuidade do processo licitatório.

Para que haja celeridade e eficácia no processo de avaliação, caso seja identificado o não atendimento às exigências mínimas deste roteiro, a equipe técnica desta administração irá considerar a Solução como "Não Conforme", momento em que a empresa proponente será desclassificada.

Neste caso, não haverá necessidade da continuidade da avaliação, haja vista que não há a prerrogativa de atendimento parcial, mas sim a obrigatoriedade de atendimento integral às parcelas de maior relevância abaixo indicadas.

1. Console de Gerenciamento de Chaves Criptográficas	**ATENDE OU NÃO ATENDE AO REQUISITO**
1.1. Apresentar a console de gerenciamento que deverá ser composta por um conjunto integrado de produtos baseados em uma infraestrutura comum e extensível, com gerenciamento centralizado de políticas e de chaves;	
1.2. Comprovar que a console única permite o gerenciamento centralizado de todos os agentes ou equivalentes de criptografia, suas chaves de criptografia, políticas de configuração, publicação e controle de acesso dos dados a serem protegidos;;	
1.3. Deverá demonstrar a capacidade da console de criar e gerenciar as chaves criptográficas nos diferentes formatos de AES, ARIA, RSA e EC.;	
1.4. Apresentar as configurações disponíveis para criptografar, controlar o acesso ao dado e oferecer registros de auditoria de acesso aos dados;	

1.5. Comprovar a integração com SIEM através do envio de eventos;	
1.6. Apresentar a capacidade de ser configurada em alta disponibilidade (HA);	
1.7. Comprovar que os agentes ou equivalentes instalados nos servidores operam de forma autônoma não causando impacto em caso de perda de comunicação com a console;	
1.8. Comprovar que promove criptografia e a rotação das chaves criptográficas com o dado em uso, sem a necessidade de indisponibilidade nos servidores;	
1.9. Comprovar que detalhes das chaves criptográficas não sejam divulgados para usuários do sistema;	
1.10. Comprovar que a console possui a capacidade de gerenciar chaves criptográficas padrão KMIP;	
1.11. Comprovar suporte multitenant com a configuração de segurança de vários domínios;	
1.12. Comprovar a segregação de funções permitindo que diferentes usuários possuam diferentes funções dentro do ambiente;	
1.13. Comprovar o acesso via interface Web, comandos CLI e API (REST);	
1.14. Comprovar a autenticação de usuário e senha e, opcionalmente, certificado digital;	
1.15. Demonstrar o suporte para configuração de cópias de segurança (backup) de suas configurações automaticamente ou manualmente; 1.16. Demonstrar que os dados não podem ser acessados fora do ambiente gerenciado pela plataforma de segurança;	

2. Criptografia para Sistemas de Arquivos de Servidores	**ATENDE OU NÃO ATENDE AO REQUISITO**
2.1. Demonstrar a operação do agente ou equivalente no sistema operacional onde a criptografia e a descriptografia devem ser transparentes para todos os aplicativos;	
2.2. Comprovar que a solução oferece mecanismos de prevenção de infecção ou ataques ao sistema de arquivos por malware, APT, ramsonware, acesso não autorizado, modificações em bibliotecas entre outros, mesmo quando estes forem originados de usuários com acesso privilegiado.;	
2.3. Demonstrar a capacidade de integração com ambientes de microserviços via Kubernetes;	

2.4. Demonstrar a operação do agente em pelo menos um servidor Microsoft e um Linux;	
2.5. Demonstrar que a implementação não exige qualquer alteração no servidor de arquivo ou processo para manuseio do dado pelo usuário final;	
2.6. Comprovar que o uso não deve gerar uma carga computacional adicional em servidores acima de 10%;	
2.7. Demonstrar a capacidade de criptografar arquivo, volume ou diretório;	
2.8. Demonstrar que nas estações de trabalho clientes do servidor não há necessidade de instalação de agentes, bem como não solicitar autenticação adicional durante o acesso aos dados criptografados no servidor;;	
2.9. Apresentar o registro e rastreabilidade do acesso dos usuários aos arquivos e bloquear ou restringir este acesso;	
2.10. Demonstrar que usuários privilegiados do sistema operacional não possuem autoridade para desfazer a política de acesso na tentativa de elevar novamente seu privilégio;	
2.11. Demonstrar que os agentes armazenam as chaves de criptografia em memória e que eles não exijam conectividade com a console de para poder aplicar processos de criptografia e descriptografia;	
2.12. Apresentar os registros de todas as tentativas de acesso permitido e negado de usuários e aplicativos;	
2.13. Demonstrar que os eventos (logs) de atividade do usuário podem ser enviados para uma solução de SIEM;	
2.14. Apresentar os registros de todas as tentativas de acesso permitido, negado de usuários, aplicativos e processos;	
2.15. Apresentar as políticas de acesso baseadas em função para controlar quem, o que, onde, quando e como os dados podem ser acessados;	
2.16. Demonstrar que os usuários privilegiados não podem acessar o conteúdo nem alterar atributos e privilégios de arquivos protegidos;	

3. Comprovar as seguintes funcionalidades para criptografia para compartilhamento seguro de bases de dados	**ATENDE OU NÃO ATENDE**

	AO REQUISITO
3.1. Demonstrar o mascaramento dos dados para permitir o compartilhamento seguro com terceiros, ambientes de teste, ambientes de desenvolvimento e outros casos de uso aplicáveis;	
3.2. Demonstrar que o mascaramento pode ser realizado baseado em tabela e/ou coluna;	
3.3. Demonstrar que a solução suporta, pelo menos, as operações de criptografia (toquenização) e descriptografia (detoquenização) de tabelas e / ou colunas;	
3.4. Demonstrar que a solução não requer alterações ou instalações adicionais no servidor de banco de dados;	
3.5. Demonstrar que a solução permite a replicação de arquivo para arquivo, banco de dados para banco de dados, arquivo para banco de dados e banco de dados para arquivo;	

4. Criptografia de Registros em Bancos de Dados via Aplicações Web	**ATENDE OU NÃO ATENDE AO REQUISITO**
4.1. Demonstrar a toquenização com mascaramento dinâmico, para promover a anonimização e pseudonimização de dados;	
4.2. Demonstrar a interface REST API com chamadas individuais e em lote;	
4.3. Demonstrar a geração de Tokens Aleatórios;	
4.4. Demonstrar o gerenciamento de chaves e políticas;	
4.5. Demonstrar o suporte a dados numéricos e alfanuméricos;	
4.6. Demonstrar a criação de tokens em formatos numéricos, de texto e de data;	
4.7. Apresentar a configuração de grupos de usuários para definir quais informações (mascaramento) são exibidas para grupos específicos;	
4.8. Demonstrar que a restrição do acesso não altera os esquemas do banco de dados e nem causam interrupções;	

5. Solução de gestão de identidades e acesso	**ATENDE OU NÃO ATENDE**

	AO REQUISITO
5.1. Apresentar visibilidade e gerenciamento de todos os serviços e usuários;	
5.2. Demonstrar que a solução suporta diversos fatores de autenticação;	
5.3. Demonstrar possuir políticas granulares para esses tokens;	
5.4. Demonstrar o suporte aos sistemas operacionais Windows e MAC OS;	
5.5. Demonstrar o suporte para os dispositivos móveis Android e Apple IOS;	
5.6. Demonstrar a capacidade de identificar o dispositivo pelo sistema operacional;	
5.7. Demonstrar gestão de risco através de políticas de contexto, tais como: Rede, Sistema Operacional, Dispositivo e Localização;	
5.8. Demonstrar os relatórios de auditoria e exportação de dados;	
5.9. Demonstrar a capacidade de criar políticas de acordo com cada perfil ou grupo de usuários;	
5.10. Demonstrar a capacidade de criar políticas de acordo com cada aplicação;	
5.11. Demonstrar que a solução permite Single Sign on (SSO);	
5.12. Demonstrar o dashboard com os acessos por aplicação (Acessos validos e negados);	
5.13. Demonstrar o dashboard com os acessos por políticas (Acessos Válidos e negados);	
5.14. Demonstrar informações a respeito de qual IP está sendo feita a autenticação, e qual método utilizado para o duplo fator de autenticação;	
5.15. Demonstrar um portal para o usuário final consolidando todas a aplicações nas quais ele tem acesso;	

6. Solução de prevenção de vazamento de dados	**ATENDE OU NÃO ATENDE AO REQUISITO**
6.1. Demonstrar a capacidade de detectar e identificar dados acessados pelo usuário;	
6.2. Demonstrar o gerenciamento por uma console separadamente das estações de trabalho;	
6.3. Demonstrar as regras para proteger dados confidenciais contra vazamentos;	
6.4. Demonstrar a capacidade de restringir as regras de proteção de dados a grupos de usuários do serviço de diretórios;	

6.5. Demonstrar a capacidade de restringir as regras de proteção de dados a grupos de máquinas ou equipamentos que fazem parte da mesma faixa de endereços IP;	
6.6. Demonstrar as técnicas e dicionários de reconhecimento de padrões de texto predefinidos;	
6.7. Demonstrar o método de identificação e rastreamento de conteúdo;	
6.8. Demonstrar a capacidade de criar regras para identificar conteúdo sensível e tomar uma ação específica;	
6.9. Demonstrar, além dos modelos já incluídos na solução, a criação de padrões e dicionários avançados para identificar informações confidenciais nas estações de trabalho;	

7. Solução de gestão de credenciais de alto privilégio	**ATENDE OU NÃO ATENDE AO REQUISITO**
7.1. Comprovar a autenticação transparente no sistema-alvo ou dispositivo de rede injetando diretamente as credenciais na tela de login e servindo como um proxy para a sessão entre o usuário e o sistema-alvo, de forma que a senha não seja exposta ao solicitante do acesso;	
7.2. Comprovar a geração de vídeos ou logs de textos das sessões realizadas através da solução;	
7.3. Comprovar que a solução possibilita gerenciamento e utilização da solução através de interface Web;	
7.4. Comprovar que a solução possui compatibilidade com, pelo menos, navegadores Microsoft Edge, Firefox, Google Chrome e Safari;	
7.5. Comprovar que a solução opera como proxy de conexões via SSH/TELNET para qualquer dispositivo gerenciado através de clientes SSH;	
7.6. Comprovar que a solução oferece conexões RDP controladas por meio de JUMP SERVER;	
7.7. Comprovar que a solução possui integração nativa com soluções de SIEM/Syslog;	
7.8. Comprovar que a solução possui modelos (templates) de troca de senha de forma que possam ser abertos, editáveis e auditáveis;	
7.9. Comprovar que a solução não depende de sistema operacional externo e/ou banco de dados que gerem a necessidade de licenças adicionais de outros fabricantes.	

7.10. Comprovar que a solução possui opções de Dashboards para operação e gestão da ferramenta;	
7.11. Comprovar que a solução gerencia o ambiente sem a necessidade de instalação de agentes ou qualquer software nos sistemas-alvos ou dispositivos de rede;	
7.12. Comprovar que a solução possui a geração automática de senhas de alta complexidade;	
7.13. Comprovar que a solução realiza a troca automática das senhas;	
7.14. Comprovar que a solução possui o monitoramento online do uso das contas e desligamento da sessão;	
7.15. Comprovar que a solução possui recurso para acesso de emergência às contas.	